

GRUPO I – CLASSE V – Plenário

TC 021.792/2013-5

Natureza: Relatório de Auditoria

Entidade: Fundação Universidade Federal do Amazonas

Advogado constituído nos autos: não há.

SUMÁRIO: AUDITORIA OPERACIONAL. FUNDAÇÃO UNIVERSIDADE FEDERAL DO AMAZONAS. FISCALIZAÇÃO INTEGRANTE DA PRIMEIRA FASE DO TRABALHO DE FISCALIZAÇÃO DE GOVERNANÇA DE TECNOLOGIA DA INFORMAÇÃO (TI) COM FOCO NA AVALIAÇÃO DA ENTREGA DE RESULTADOS E NA GESTÃO DE RISCOS, REALIZADO NA SISTEMÁTICA DE FISCALIZAÇÃO DE ORIENTAÇÃO CENTRALIZADA (FOC). DETERMINAÇÕES. RECOMENDAÇÕES.

Relatório

Trata-se de auditoria integrante do conjunto de auditorias da primeira fase do trabalho de fiscalização de governança de tecnologia da informação (TI) com foco na avaliação da entrega de resultados e na gestão de riscos, realizado na sistemática de Fiscalização de Orientação Centralizada (FOC).

2. O objetivo da auditoria foi avaliar a implementação dos controles informados pela Fundação Universidade Federal do Amazonas (UFAM) em resposta ao levantamento do perfil de governança de TI realizado em 2012, bem como verificar e avaliar a adoção pela entidade auditada de planos e estratégias para implementação e melhoria da governança e da gestão de TI.

3. Transcrevo a seguir excerto do relatório de auditoria elaborado pela equipe da Secex-AM responsável pelos trabalhos:

"2. Introdução

2.1. Antecedentes (Deliberação)

7. No item 9.4.3 do Acórdão 2.308/2010-TCU-Plenário (2º Levantamento de Governança de TI), o TCU determinou à Sefti que mantenha processo de trabalho permanente e sustentável de acompanhamento da governança de TI na Administração Pública Federal, de modo a subsidiar processos de fiscalização do TCU em TI e processos de planejamento e controle das unidades jurisdicionadas, com a definição, se possível, da realização periódica de levantamentos gerais e de mecanismos para a coleta de evidências destinadas a aumentar a confiabilidade das informações colhidas mediante questionários.

8. Com efeito, a presente fiscalização foi autorizada mediante Despacho do Ministro-Relator Weder de Oliveira (peça 3), proferido no âmbito do TC 012.164/2013-5. No referido despacho, foi aprovada a sistemática de FOC em duas fases, sendo que este trabalho integra o conjunto de auditorias da primeira fase.

2.2 Objetivos e Questões de Auditoria

9. O principal objetivo desta fiscalização foi avaliar a implementação dos controles de TI informados em resposta ao levantamento do perfil de governança de TI realizado pelo TCU em 2012, bem como verificar a adoção de planos e estratégias para implementação e melhoria da governança de TI.

10. Dessa forma, com base no objetivo da fiscalização e a fim de avaliar a aderência da Fundação Universidade do Amazonas às melhores práticas de governança e de gestão de TI, foram elaboradas seis questões de auditoria, agrupadas neste relatório em cinco temas, conforme ilustra a tabela a seguir:

Temas	Questões de auditoria
Governança corporativa	Os mecanismos de governança corporativa foram definidos e implementados adequadamente no âmbito da instituição?
Governança de TI	Há um processo de aprimoramento da governança de TI segundo as boas práticas? Os mecanismos de governança de TI foram definidos e implementados adequadamente no âmbito da instituição?
Estratégias e Planos	As estratégias e planos corporativos e de TI foram definidos e implementados adequadamente no âmbito da instituição?
Gestão de Pessoas de TI	Os mecanismos de gestão de pessoal de TI foram definidos e implementados adequadamente no âmbito da instituição?
Processos	Os processos de TI foram definidos e implementados adequadamente no âmbito da instituição?

2.3 Visão Geral

11. A governança de TI, segundo a ABNT NBR ISO/IEC 38500 (item 1.6.3), é o sistema pelo qual o uso atual e futuro da TI é dirigido e controlado. O *IT Governance Institute* (ITGI) – organismo internacional responsável por pesquisas sobre práticas e percepções globais de governança de TI para a comunidade – estabelece que “a governança de TI é de responsabilidade dos executivos e da alta direção, consistindo em aspectos de liderança, estrutura organizacional e processos que garantam que a área de TI da organização suporte e aprimore os objetivos e as estratégias da organização”.

12. Pode-se afirmar que a governança de TI é uma parte da governança corporativa que, em suma, consiste no estabelecimento de um conjunto de mecanismos com o objetivo de assegurar que o uso da TI agregue valor ao negócio com riscos aceitáveis, sendo responsabilidade dos executivos e da alta administração da organização prover a estrutura e garantir uma boa governança de TI.

13. Esse tema tem sido explorado pelo TCU, de forma mais específica, por meio de levantamentos realizados para avaliar a situação de governança de TI, bem como mediante diversas ações no sentido de disseminar, além dos resultados e boas práticas identificados, os conceitos tratados nesses trabalhos, buscando sempre destacar a importância da governança de TI para a Administração Pública Federal (APF).

14. O primeiro levantamento, realizado em 2007, contou com a participação de 255 instituições, resultando no Acórdão 1.603/2008-TCU-Plenário. O segundo levantamento, organizado em 2010, avaliou 301 instituições, culminando no Acórdão 2.308/2010-TCU-Plenário, que apresentou, pela primeira vez, a evolução da situação de governança de TI na APF. Por fim, o terceiro levantamento, realizado em 2012, avaliou 350 instituições, dando origem ao Acórdão 2.585/2012-TCU-Plenário.

15. De modo geral as informações, obtidas nos levantamentos de governança de TI realizados pelo TCU, visam à identificação dos pontos mais vulneráveis da governança de TI na APF, à orientação da atuação do TCU como indutor do processo de aperfeiçoamento da governança de TI, bem como ao auxílio na identificação de bons exemplos e modelos a serem disseminados.

16. Nesse contexto, definiu-se como objeto desta auditoria um subconjunto dos mecanismos avaliados no âmbito do levantamento do perfil de governança de TI realizado pelo TCU em 2012, bem como o processo de aprimoramento da governança de TI na Fundação Universidade do Amazonas. Em síntese, foram avaliados aspectos ligados à governança corporativa, à governança de TI, às estratégias e planos da Entidade, à gestão de pessoas e à gestão de processos de TI.

2.4 Critérios e Metodologia

17. Para a realização deste trabalho, foram seguidos os normativos institucionais que tratam das fiscalizações no âmbito do TCU, em especial os documentos intitulados “Manual de Auditoria Operacional”, aprovado pela Portaria-Segecex 4/2010; “Orientações para fiscalizações de Orientação Centralizada”, aprovadas pela Portaria-Adplan 2/2010; e “Normas de Auditoria do TCU” (NAT), aprovadas por meio da Portaria-TCU 280/2010, posteriormente alterada pela Portaria-TCU 168/2011.

18. Durante a fase de planejamento da FOC, a unidade técnica orientadora dos trabalhos definiu as questões e os procedimentos de auditoria com base nos itens do questionário utilizado no levantamento do perfil de governança de TI de 2012. Como resultado dessa fase, foi gerada a matriz de planejamento da auditoria, cujo conteúdo foi transmitido durante *workshop* realizado em Brasília com membros das equipes de fiscalização das unidades executoras da FOC.

19. Ressalte-se que a equipe desta auditoria recebeu, durante uma semana na fase de planejamento, apoio técnico de auditor da equipe de coordenação da FOC com o objetivo de auxiliar na aplicação dos procedimentos de auditoria contidos na matriz de planejamento, de fornecer esclarecimentos sobre conceitos ligados à gestão e à governança de TI, além de participar de reuniões técnicas com gestores da Fundação.

20. Além de dispositivos constitucionais, legais e infralegais, foram utilizados como critérios decisões do TCU relacionadas à governança e à gestão de TI, em especial o Acórdão 1.233/2012-TCU-Plenário. Também foram utilizados como critérios o guia Cobit 5, da *Information Systems Audit and Control Association* (Isaca); as normas NBR ISO/IEC 27.002:2005 (NBR 27.002), 20000-2:2008 (NBR 20000-2) e 38500:2009 (NBR 38500); o Código de Melhores Práticas de Governança Corporativa do Instituto Brasileiro de Governança Corporativa (IBGC); e o Guia de Elaboração de Plano Diretor de Tecnologia da Informação (PDTI) do Sistema de Administração dos Recursos de Tecnologia da Informação (SisP).

21. O Cobit 5 consiste em um modelo de boas práticas para governança e gestão de tecnologia da informação organizado em cinco grandes domínios: *Evaluate, Direct and Monitor* (EDM), *Align, Plan and Organize* (APO), *Build, Acquire and Implement* (BAI), *Deliver, Service and Support* (DSS) e *Monitor, Evaluate and Assess* (MEA), cujas siglas serão utilizadas no decorrer do relatório para fins de referência ao critério de auditoria.

22. A NBR 27.002 consiste em um código de boas práticas para a gestão da segurança da informação amplamente adotado no mundo e tem como propósito prover uma base comum para o desenvolvimento de normas de segurança organizacional e das práticas efetivas de gestão da segurança, além de prover confiança nos relacionamentos entre as organizações, fornecendo aos seus usuários recomendações para a boa gestão da segurança da informação.

23. Por sua vez, a NBR 20000-2 estabelece um código de prática que descreve as melhores práticas para processos de gerenciamento de serviços dentro do escopo da ABNT NBR ISO/IEC 20000-1. Essa norma faz parte da série ABNT NBR ISO/IEC 20000, que habilita provedores de serviços a entender como melhorar a qualidade dos serviços entregues aos seus clientes, tanto internos como externos.

24. Já a NBR ISO/IEC 38500 – norma de governança corporativa em tecnologia da informação – tem por objetivo fornecer uma estrutura de princípios para os dirigentes usarem na avaliação, no gerenciamento e no monitoramento do uso da tecnologia da informação em suas organizações. Essa norma oferece uma estrutura (contendo definições, princípios e um modelo) para a governança eficaz de TI que ajuda a alta administração das organizações a entender e cumprir suas obrigações legais, regulamentares e éticas com relação ao uso da TI em suas organizações.

25. O Código de Melhores Práticas de Governança Corporativa do IBGC propõe a adoção de princípios e boas práticas de governança corporativa, com vistas a reduzir eventuais fragilidades no sistema de governança das organizações, que se aplicam a qualquer tipo de organização, independentemente do porte, natureza jurídica ou tipo de controle. O código é

adotado como referência para alguns controles e práticas que ajudam a orientar a organização como um todo e, por consequência, sua atuação na governança da TI.

26. Por fim, o Guia de Elaboração de PDTI do Sisp provê informações que ajudam as organizações a planejarem melhor as ações relacionadas à TI. Cabe ressaltar que, apesar do referido guia ser destinado às instituições que fazem parte do Sistema de Administração dos Recursos de Tecnologia da Informação (Sisp), considerou-se que as informações ali contidas são boas práticas que poderiam ser aplicadas para as demais instituições fiscalizadas neste trabalho.

2.5 Limitações ocorridas

27. Não ocorreram limitações aos trabalhos de auditoria.

3. Governança Corporativa

28. Governança Corporativa é o sistema pelo qual as organizações são dirigidas, monitoradas e incentivadas, envolvendo os relacionamentos entre proprietários, conselho de administração, diretoria e órgãos de controle. As boas práticas de governança corporativa convertem princípios em recomendações objetivas, alinhando interesses com a finalidade de preservar e otimizar o valor da organização, facilitando seu acesso a recursos e contribuindo para sua longevidade. Os princípios básicos de governança corporativa são a transparência, a equidade, a prestação de contas e a responsabilidade corporativa.

29. A governança da área de TI não está isolada no ambiente corporativo, mas sim conectada ao ambiente geral da organização. A atuação da área de TI é diretamente influenciada pela direção e pela organização da instituição, logo há uma dependência entre a governança de TI e a governança institucional.

30. Neste trabalho, os seguintes aspectos relacionados à governança corporativa, parte integrante do levantamento de governança de TI, foram avaliados:

a) atuação da alta administração quanto ao estabelecimento e monitoramento de políticas corporativas (liderança);

b) comitê de direção estratégica;

c) ética institucional.

31. De acordo com o Estatuto da Fundação Universidade do Amazonas, aprovado pela Portaria MEC 1.344/2000, a administração superior da entidade é exercida pela Reitoria, por seis câmaras setoriais, com funções deliberativas, normativas e consultivas, e por três conselhos, que auxiliam a Reitoria nas decisões relativas às diretrizes, estratégias, políticas e acompanhamento da gestão institucional. Os conselhos são:

a) Conselho Universitário (Consuni), com funções deliberativas e normativas;

b) Conselho de Administração (Consad), com funções consultivas, deliberativas e normativas; e

c) Conselho de Ensino, Pesquisa e Extensão (Consepe), com funções consultivas, deliberativas e normativas.

3.1. Atuação insuficiente da alta administração no estabelecimento e monitoramento de políticas corporativas.

32. A alta administração não estabeleceu algumas das principais políticas corporativas, tais como política de segurança da informação e política de governança de TI.

Critérios

32.1. Item 2.3 – Atribuições do Conselho de Administração - Código das Melhores Práticas de Governança Corporativa do IBGC.

Análise das evidências

32.2. Em resposta ao Ofício 0837/2013-TCU/Secex-AM (peça 4), a Ufam informou não possuir política de segurança da informação, política de governança de TI ou outra política corporativa (peça 7, p. 2). Verifica-se que, em 8/1/2013, foi encaminhada à Reitoria minuta contendo política de segurança da informação (peça 12), mas até a conclusão deste trabalho de auditoria, a Ufam não concluiu sua aprovação. Sobre a política de governança de TI, nada foi informado.

Causas

32.3. Falha no estabelecimento de políticas corporativas.

Efeitos e riscos decorrentes da manutenção da situação encontrada

32.4. Ausência de diretrizes que guiem a Ufam para a preservação e otimização do valor organizacional.

Conclusão

32.5. Não há, por parte da alta administração, o estabelecimento de políticas corporativas relativas à segurança da informação ou governança de TI. A única iniciativa relatada nesse sentido é a elaboração de uma minuta de política de segurança da informação, que partiu do Centro de Processamento de Dados (CPD) da Ufam, mas que ainda não foi aprovada pela alta administração.

Proposta de encaminhamento

32.6. Recomendar à Fundação Universidade do Amazonas que, com base nas boas práticas contidas na seção 2.3 do Código das Melhores Práticas de Governança Corporativa do IBGC, sensibilize os membros da alta administração acerca de sua responsabilidade em estabelecer e monitorar as políticas corporativas do órgão, a exemplo da política de segurança da informação e das demais políticas relativas à governança de tecnologia da informação.

3.2. Falhas na aplicação do código de ética.

33. A Ufam não dá ampla divulgação ao código de ética adotado pela entidade a seus servidores.

Critérios

33.1. Decreto 6.029/2007, art. 7º, inciso II, alínea “d”.

Análise das evidências

33.2. A Ufam não possui código de ética próprio, tendo adotado tacitamente o Decreto 6.029/2007 como seu código de ética. Os gestores foram indagados sobre a disponibilidade do código de ética na intranet da Ufam, tendo respondido que o mesmo não se encontra disponível na intranet da entidade.

33.3. A Ufam informou que torna conhecido o folheto do Código de Ética nos seminário de integração dos novos servidores, e que providenciou a divulgação do referido código na página da Universidade (peça 7, p. 2). Entretanto, verifica-se que não há campanhas periódicas de divulgação do código de ética para todos os servidores da instituição. Sobre a divulgação do aludido código na página de internet da entidade, não foram encontradas evidências que confirmem esta informação.

33.4. Verifica-se que existe uma comissão de ética instituída na Ufam, tendo sido encaminhada ata de reunião realizada em 2010 pela referida comissão (peça 8, p. 9-10). Contudo, tal documento comprova tão somente a atuação da comissão, e não a ampla divulgação do código de ética adotado na entidade.

Causas

33.5. Falta de providências da instituição no sentido da ampla divulgação do código de ética.

Efeitos e riscos decorrentes da manutenção da situação encontrada

33.6. Desconhecimento do código de ética por parte dos membros da Universidade do Amazonas (efeito potencial).

Conclusão

33.7. A Universidade, assim como as demais entidades do poder executivo federal, devem desenvolver ações objetivando a disseminação, capacitação e treinamento sobre as normas de ética e disciplina. Desta forma, em atendimento ao disposto no Decreto 6.029/2007, art. 7º, inciso II, alínea “d”, a Ufam deve dar ampla divulgação do código de ética, incluindo mecanismos que garantam o fácil acesso deste por parte de seus servidores, como por exemplo, divulgação em sua intranet.

Proposta de encaminhamento

33.8. Determinar à Fundação Universidade do Amazonas que, em atenção ao art. 7º, inciso II, alínea “d” do Decreto 6.029/2007, dê ampla divulgação do código de ética, incluindo mecanismos que garantam o fácil acesso deste por parte de seus servidores, como por exemplo, divulgação em sua intranet.

4. Governança de TI

34. A governança de TI compreende a análise do ambiente corporativo, implantando e provendo sustentação a estruturas organizacionais, princípios, processos e práticas, com divisão clara de responsabilidades e delegação de autoridade, no sentido de se atingir a missão, as metas e os objetivos organizacionais, e, ao mesmo, tempo gerenciando os riscos existentes.

35. A governança de TI objetiva, assim, prover uma abordagem consistente e integrada à governança corporativa para assegurar que as decisões de TI estejam de acordo com as estratégias e objetivos organizacionais. Espera-se, dessa forma, que seja possível assegurar que os processos de TI sejam monitorados e utilizem os recursos disponíveis de forma eficiente e em conformidade com os requisitos legais e regulatórios.

36. Nesse sentido, a presente avaliação compreendeu diversos aspectos que formam o arcabouço de governança de TI que tem sido objeto de avaliação nos levantamentos de governança conduzidos pelo TCU, a saber:

- a) políticas de governança, gestão e uso de TI;
- b) processo de melhoria do próprio sistema de governança de TI;
- c) mecanismo decisório e de priorização das demandas da TI;
- d) organização das responsabilidades quanto à governança, gestão e uso de TI;
- e) diretrizes formuladas pela alta administração;
- f) mecanismos adotados para o monitoramento das diretrizes, das políticas e dos princípios estabelecidos.

37. No que tange à responsabilidade pelas políticas corporativas de TI, o Acórdão 2.308/2010-TCU-Plenário, em seu item 9.1 e respectivos subitens, recomendou aos órgãos governantes superiores (OGS) que orientassem as instituições sob sua jurisdição sobre a necessidade de a alta administração responsabilizar-se formalmente pelas políticas de TI, com o estabelecimento de objetivos, indicadores e metas de TI, bem como com mecanismos para avaliação do desempenho de TI.

38. Para a organização ter condições de avaliar seu desempenho na gestão e no uso de TI, é necessário estabelecer objetivos institucionais de TI, indicadores de desempenhos para cada objetivo, metas para cada indicador e monitorar regularmente esses indicadores, conforme recomendado no item 9.1 do Acórdão 2.308/2010-TCU-Plenário.

39. Sobre o panorama da governança de TI na Fundação Universidade do Amazonas, cabe destacar, inicialmente, que a Ufam não dispõe de normas que definam diretrizes para as seguintes questões de governança de TI: gestão dos riscos aos quais o negócio está exposto; gestão da segurança da informação corporativa; contratação de bens e serviços de TI e para avaliação de seus resultados em termos do negócio institucional; avaliação do desempenho dos serviços de TI junto às unidades usuárias em termos de resultado de negócio institucional; gestão do portfólio de projetos e serviços de TI, inclusive para definição de critérios de sua priorização, inclusão, exclusão, manutenção e suprimento orçamentário; obtenção, desenvolvimento e retenção de competência de pessoal.

40. Segundo informações contidas no Ofício 449/2013/GR/Ufam (peça 7, p. 3), a definição de diretrizes para a gestão dos riscos aos quais o negócio está exposto, a exemplo de uma política de gestão de riscos da organização, seria atribuição da comissão de tecnologia da informação e comunicação (Comtic). Da mesma forma, a Comtic seria responsável pela avaliação do desempenho dos serviços de TI junto às unidades usuárias em termos de resultado de negócio institucional, e pela gestão do portfólio de projetos e serviços de TI. Contudo, verifica-se que a Portaria 678/2012 (peça 18), que instituiu a Comtic e define suas atribuições, não prevê tais atribuições à esta comissão.

41. Conforme reconheceu a própria Ufam, por meio do Ofício 449/2013/GR/Ufam (peça 7, p. 3), não existem normas que estabeleçam diretrizes para a gestão da segurança da informação. Tampouco possuem normas que definam diretrizes para contratação de bens e serviços de TI e avaliação de seus resultados em termos de negócio.

42. Por fim, em resposta ao questionamento feito sobre as diretrizes para obtenção, desenvolvimento e retenção de competências de pessoal, a Ufam informou que possui uma minuta de reforma administrativa do CPD, que contempla um escritório de projetos, e que tal escritório, mesmo sem a aprovação formal da proposta de reforma administrativa, já funciona com três servidores. Todavia, verifica-se que a instalação de um escritório de projetos não pode ser considerado suficiente para suprir a ausência de diretrizes para a obtenção, desenvolvimento e retenção de competências de pessoal. As diretrizes devem ser mais amplas, alinhadas com os princípios da estrutura para uma boa governança corporativa de TI, descritos no item 2 da norma NBR ISO/IEC 38.500.

4.1. Deficiência nas ações de melhoria de governança de TI

43. A Fundação Universidade do Amazonas não desenvolve ações específicas voltadas à melhoria da governança de TI.

Critérios

43.1. Norma Técnica – ITGI – Cobit 5 Framework, Capítulo 7 – Guia de Implementação;

43.2. Norma Técnica – ITGI – Cobit 5 - Implementação, Guia de Referência - Capítulo 3 - Adotando os primeiros passos em direção à governança de TI;

43.3. Acórdão 2.585/2012, item 9.1.1.3., Tribunal de Contas da União, Plenário;

Análise das evidências

43.4. Constatou-se, pelos documentos enviados pela Ufam, e pelas respostas contidas no Ofício 449/2013/GR/Ufam (peça 7), que a Entidade não dispõe de um processo de aprimoramento contínuo da governança de TI. Não foram identificadas ações com intuito de diagnosticar o nível de maturidade em governança de TI, e nem a definição de metas de governança para os próximos exercícios. A Instituição também não possui estrutura de pessoal formalmente alocada para a melhoria de governança de TI.

Causas

43.5. Nível de comprometimento insuficiente da instituição com a melhoria da governança de TI.

Efeitos e riscos decorrentes da manutenção da situação encontrada

43.6. Ausência de governança de TI em nível adequado para o alcance dos objetivos de TI da instituição (efeito potencial).

Conclusão

43.7. A Universidade do Amazonas não está desenvolvendo ações que objetivem aprimorar seu nível de governança em TI. Tal situação de inércia pode comprometer a evolução do nível de maturidade da sua governança de TI, bem como, em última análise, pode prejudicar o alcance dos objetivos de TI, sendo cabível recomendação para que se adotem providências no sentido de estabelecer ações para o desenvolvimento e aprimoramento da governança de TI na Ufam.

Proposta de encaminhamento

43.8. Recomendar à Fundação Universidade do Amazonas que elabore e aprove formalmente um processo de aprimoramento contínuo da governança de TI, a exemplo das boas práticas contidas no capítulo 3 do guia de referência da implementação do Cobit 5, que contemple pelo menos o seguinte:

a) definição de papéis e responsabilidades voltadas especificamente para a melhoria da governança de TI;

b) realização de diagnósticos ou autoavaliações de governança e de gestão de TI;

c) definição e acompanhamento de metas de governança de TI e das ações necessárias para alcançá-las, com base em parâmetros de governança, necessidades de negócio e riscos relevantes.

4.2. Falhas na implementação do Comitê de TI

44. O comitê de TI da Universidade não tem, em sua composição, representantes das principais áreas do negócio. Ademais, tal comitê foi designado formalmente, mas não realizou nenhuma reunião.

Critérios

44.1. Acórdão 1.233/2012, item 9.1.1.3., Tribunal de Contas da União, Plenário;

44.2. Estratégia Geral de Tecnologia da Informação (EGTI) do Sistema de Administração dos Recursos de Informação e Informática (SISP) para o biênio 2011-2012, aprovada pela Resolução SISP 7 de 22/12/2010. Meta 5, Iniciativa Estratégica 12.

Análise das evidências

44.3. A Entidade, por meio da Portaria 678/2012 (peça 18), instituiu a comissão de tecnologia de informação e comunicação (Comtic). A referida portaria define a seguinte composição do Comtic:

a) diretor do CPD, na condição de presidente;

b) reitor da Ufam, tendo como seu suplente o vice-reitor;

c) pró-reitor de planejamento;

d) pró-reitor de administração;

e) assessor especial de informática;

f) diretor do Instituto de Computação.

44.4. Observa-se que, na sua composição, a Comtic está adstrita a representantes da área administrativa, ou ligados a tecnologia da informação. Contudo, deve-se ponderar que a Ufam, enquanto instituição de ensino superior, tem como finalidade precípua o ensino e pesquisa. Assim, considera-se que tal comitê deveria ser composto também por representantes

destas áreas, em especial a pró-reitoria de pesquisa e pós-graduação (Propesp) e a pró-reitoria de ensino de graduação (Proeg).

44.5. Sobre a atuação da Comtic, verifica-se pelas respostas contidas no Ofício 449/2013/GR/Ufam (peça 7), que este comitê, apesar de constituído formalmente desde 13/3/2012, ainda não realizou qualquer reunião. Desta forma, não vem cumprido o papel para o qual foi criado. Ressalte-se que o art. 5º da Portaria 678/2012 prevê reuniões mensais do sobredito comitê. Os gestores da Ufam informaram que o comitê ainda não se reuniu pela dificuldade de alinhar as agendas dos seus componentes.

Causas

44.6. Nível de comprometimento insuficiente da instituição com as necessidades de priorização e de investimento de TI.

Efeitos e riscos decorrentes da manutenção da situação encontrada

44.7. A ausência de representantes de área relevantes para o negócio institucional, principalmente aqueles ligados às pró-reitorias de ensino e pesquisa, pode resultar em deliberações da Comtic que não estejam alinhadas aos objetivos dessas áreas de grande importância para a Ufam (efeito potencial).

44.8. A inatividade da Comtic leva à não elaboração ou acompanhamento de políticas e planos ligados à governança corporativa de TI, a exemplo da preparação e acompanhamento do PDTI, estabelecimento de normas de segurança de TI, priorização de projetos e definição de prioridades de investimentos em TI, entre outros, todos previstos como atribuição da referida comissão (Portaria 678/2012, art. 4º, constante à peça 18).

Conclusão

44.9. A comissão de tecnologia da informação e comunicação na Universidade do Amazonas não conta com representantes de todas as áreas relevantes para o seu negócio, uma vez que não estão previstos representantes das pró-reitorias ligadas ao ensino e à pesquisa. Assim, convém recomendar o aperfeiçoamento da composição da sobredita comissão.

44.10. A Comtic, apesar de formalmente constituída, não vem realizando as reuniões mensais ordinárias previstas na Portaria 678/2012. De fato, desde a sua criação, em março de 2012, não se reuniu uma única vez, e desta forma, não vem cumprindo o papel para o qual foi criada. Desta forma, cabe recomendação para que a comissão passe a atuar de fato.

Proposta de encaminhamento

44.11. Recomendar à Fundação Universidade do Amazonas que, em atenção à iniciativa estratégica 3.1 da Estratégia Geral de TI, de 2013-2015, do Sisp, e em consonância com o disposto no item 9.2.1 do Acórdão 1.233/2012-TCU-Plenário, aperfeiçoe a implementação do Comitê de Tecnologia da Informação no sentido de assegurar o seu funcionamento permanente, bem como a efetiva alocação de representantes de áreas relevantes para o negócio da entidade, em especial representantes das áreas de ensino e pesquisa, que constituem o negócio da entidade, à semelhança das orientações contidas no Cobit 5, Prática de Gestão APO01.01 – *Define the organisational structure* (Definir a estrutura organizacional – tradução livre), atividades 7 e 8.

4.3. Falhas nos mecanismos para dirigir e avaliar a gestão e o uso corporativos de TI

45. A Fundação Universidade do Amazonas não estabeleceu alguns mecanismos importantes para dirigir e avaliar a gestão e o uso corporativo de TI, como por exemplo: objetivos de gestão e de uso corporativos de TI; indicadores de desempenho para cada objetivo de gestão e de uso corporativos de TI; mecanismos de controle do cumprimento das metas de gestão e de uso corporativos de TI; planos de auditoria aprovados para avaliar os riscos considerados críticos para o negócio e a eficácia dos respectivos controles; e norma que demonstre que a alta administração acompanha os indicadores de resultado estratégicos dos

principais sistemas de informação e toma decisões a respeito quando as metas de resultado não são atingidas.

Crerérios

- 45.1. Acórdão 2.308/2010, item 9.1.1, Tribunal de Contas da União, Plenário;
- 45.2. Norma Técnica – NBR ISO/IEC 38.500:2009, item 3.3.

Análise das evidências

45.3. Em resposta enviada por meio do Ofício 449/2013/GR/Ufam, os gestores da Universidade apresentaram um plano de desenvolvimento institucional (PDI), para o período 2006-2015. Esse PDI, em seus objetivos estratégicos e ações táticas por área, dedica capítulo para a área de tecnologia da informação. Existem algumas metas e indicadores estabelecidos, mas não foram explicitados mecanismos para acompanhamento das metas estabelecidas, nem prazo para alcance das mesmas. As metas instituídas não são quantificadas, e desta forma, não são mensuráveis. Os gestores também informaram que a Universidade não possui PDTI ou Plano Estratégico de TI (Peti) formalizados.

45.4. Sobre a gestão de riscos relacionados aos objetivos de gestão e uso corporativo de TI, os gestores informaram que será atribuição do escritório de segurança da informação, mas tal escritório não existe, está apenas previsto na minuta de reforma administrativa do CPD da Ufam (peça 22).

45.5. Por fim, o Ofício 449/2013/GR/Ufam (peça 7, p. 3) esclarece que, para os anos de 2010 a 2012, não foram previstas auditorias para avaliar os riscos considerados críticos para o negócio e a eficácia dos respectivos controles. Tal questão será inserida no Plano Anual de Atividade de Auditoria Interna (Paint) de 2014.

Causas

45.6. Ausência de iniciativa por parte da alta administração da Ufam para a formulação de mecanismos para dirigir e avaliar a gestão e o uso corporativos de TI.

Efeitos e riscos decorrentes da manutenção da situação encontrada

45.7. Uso não planejado da TI, sem alinhamento com as prioridades estratégicas da organização (efeito potencial).

Conclusão

45.8. Ante a ausência de planos e/ou normativos que estabeleçam mecanismos para dirigir e avaliar a gestão e o uso corporativos de TI, cabe recomendação à Ufam para que estabeleça formalmente objetivos de gestão e de uso corporativos de TI alinhados às estratégias de negócio, indicadores de desempenho para os objetivos de gestão definidos, metas de desempenho da gestão e do uso corporativos de TI para cada indicador definido, e mecanismos para que a alta administração acompanhe o desempenho da TI da instituição.

Proposta de encaminhamento

45.9. Recomendar à Fundação Universidade do Amazonas, em consonância com o disposto no item 9.1.1 do Acórdão 2.308/2010-TCU-Plenário e com base nas boas práticas contidas na seção 3.3 da ABNT NBR ISO/IEC 38500:2009, que:

45.9.1. Estabeleça formalmente:

- a) objetivos de gestão e de uso corporativos de TI alinhados às estratégias de negócio;
- b) indicadores de desempenho para os objetivos de gestão definidos;
- c) metas de desempenho da gestão e do uso corporativos de TI para cada indicador definido;

d) mecanismos para que a alta administração acompanhe o desempenho da TI da instituição;

e) mecanismos de gestão dos riscos relacionados aos objetivos de gestão e de uso corporativos de TI.

45.9.2. Aprove formalmente o plano anual de auditoria interna da entidade, que deverá conter, entre outras atividades, ações com o objetivo de fornecer avaliação objetiva à alta administração quanto é eficácia do gerenciamento de riscos.

4.4. A auditoria interna não fiscaliza a TI

46. A auditoria interna da Universidade do Amazonas não vem realizando auditorias na área de TI.

Critérios

46.1. Acórdão 1.233/2012, item 9.10.2., Tribunal de Contas da União, Plenário.

Análise das evidências

46.2. Em resposta enviada por meio do Ofício 449/2013/GR/Ufam (peça 7, p. 3), os gestores da Ufam informaram que, nos anos de 2010 e 2011, não foram realizadas auditorias por iniciativa da própria instituição sobre os seguintes temas: governança de TI, segurança da informação, sistemas de informação, contratos de TI, bancos de dados de sistemas de informação. Informaram ainda que tais atividades estarão previstas no PAINT 2014.

Causas

46.3. Falhas do planejamento das ações dos controles internos.

Efeitos e riscos decorrentes da manutenção da situação encontrada

46.4. Ocorrência de falhas não detectadas na área de TI, especialmente em: governança de TI, sistemas de informação, contratos de TI, controles de sistemas, mecanismos de segurança da informação informações nos bancos de dados que podem impactar o negócio da instituição (efeito potencial).

Conclusão

46.5. Ainda que a Ufam tenha informado que irá contemplar, em seu planejamento de auditorias para 2014, a realização de trabalhos na área de TI, cabe recomendação à Entidade para que realize auditorias periódicas em TI.

Proposta de encaminhamento

46.6. Recomendar à Fundação Universidade do Amazonas que, em consonância com o disposto no item 9.10.2 do Acórdão 1.233/2012-TCU-Plenário, realize auditorias periódicas na área de tecnologia da informação da Entidade, em especial no que diz respeito à avaliação da governança de TI, dos sistemas de informação e de suas bases de dados, da segurança da informação e das aquisições de bens e serviços de TI.

5. Estratégias e Planos

47. Conforme dispõe o Guia de Elaboração de PDTI do Sisp (seção 3.2, p. 12), traduzindo a definição de planejamento para o conceito organizacional:

[...] pode-se dizer que planejar é determinar os objetivos ou metas da organização e coordenar os meios e recursos para atingi-los. E para atingir esses objetivos satisfatoriamente, as instituições devem ter a capacidade de percepção e de organização de suas experiências e perspectivas futuras. Para isso, é necessário integrar conhecimento e conteúdo, priorizando questões relevantes com ações associadas a objetivos definidos

48. Com efeito, para melhor conduzir a instituição na busca dos seus objetivos é mandatório planejar. Porém, conforme o item 83 do relatório que fundamenta o Acórdão

2.585/2012-TCU-Plenário, ainda preocupa o fato de que muitas instituições não executam um processo de planejamento estratégico (15% do universo pesquisado declararam não realizar planejamento estratégico). De acordo com o mesmo relatório, as contratações de TI devem estar planejadas em harmonia com instrumentos que derivam do planejamento estratégico, conforme estabelece a jurisprudência do TCU (Acórdãos 1.521/2003, 1.558/2003, 2.094/2004, 786/2006 e 1.603/2008, todos do Plenário) e a Instrução Normativa 4/2010, da Secretaria de Logística e Tecnologia da Informação (IN – SLTI/MP 4/2010).

49. Contudo, não somente as contratações de TI derivam desse processo, mas sobretudo o conjunto de ações da instituição, que deve estar pautado pelos objetivos e metas estabelecidos na estratégia organizacional. Nesse sentido, o TCU recomendou aos OGS, por meio do item 9.1.1 do Acórdão 1.233/2012-TCU-Plenário, que estabelecessem a obrigatoriedade de que todos os entes sob sua jurisdição estabeleçam processo de planejamento estratégico institucional, em atenção ao princípio do planejamento expresso no art. 6º, inciso I, e no art. 7º do Decreto-Lei 200/1967.

50. Avançando-se no nível de especialização do planejamento, no âmbito do Poder Judiciário, o Conselho Nacional de Justiça, por meio da Resolução 90/2009, também estabeleceu a obrigatoriedade dos órgãos sob sua jurisdição de elaborarem o plano estratégico de tecnologia da informação (Peti) e o plano diretor de TI (PDTI). O TCU possui jurisprudência pacífica a respeito da importância do PDTI (Acórdãos 380/2011, 465/2011, 592/2011, 2612/2011, 1.233/2012, entre outros, todos do Plenário). No âmbito do Sisp, desenvolveu-se, inclusive, o Guia de Elaboração de PDTI do Sisp, que apresenta uma série de considerações a respeito desse importante instrumento.

51. Por ocasião do preenchimento do questionário utilizado no levantamento do perfil de governança de TI de 2012, a Fundação Universidade do Amazonas informou executar um processo periódico de planejamento, embora este não esteja formalmente instituído. Informou, em adição, executar de forma periódica processo de planejamento estratégico de TI, contudo sem instituição formal do referido processo, e que não aprovou e nem publicou um PDTI.

5.1. Falha no planejamento de TI

52. A Universidade do Amazonas não tem planejamento estratégico de TI (Peti) e plano diretor de TI (PDTI) formalmente aprovados e publicados.

Critérios

52.1. Constituição Federal, art. 37, *caput*;

52.2. Decreto Lei 200/1967, art. 6º, inciso I e art. 7º;

52.3. Acórdão 1.233/2012, item 9.1.2.1., Tribunal de Contas da União, Plenário;

52.4. Estratégia Geral de Tecnologia da Informação (EGTI) do Sistema de Administração dos Recursos de Informação e Informática (SISP) para o biênio 2011-2012, meta 5, iniciativa estratégica 15.

Análise das evidências

52.5. Em resposta enviada por meio do Ofício 449/2013/GR/Ufam (peça 7, p. 4), os gestores da Ufam informaram que estão executando o planejamento acostado à peça 23. Contudo, tal documento não se constitui em um Peti aprovado e publicado. Pelo mesmo ofício, ainda informaram não possuir PDTI.

52.6. Nas entrevistas realizadas com os gestores constatou-se que, ao contrário do que foi informado no questionário utilizado no levantamento do perfil de governança de TI de 2012, a Ufam não conta com um processo de planejamento estratégico de TI, e sim com um plano de TI que não foi formalmente aprovado e publicado.

Causas

52.7. Ausência de iniciativa por parte da alta administração da Ufam para a elaboração, aprovação e publicação de um plano estratégico de TI e plano diretor de TI.

Efeitos e riscos decorrentes da manutenção da situação encontrada

52.8. Aumento do risco de que a gestão e o uso da TI não sejam direcionados à geração de valor para a organização.

Conclusão

52.9. A ausência de formalização e publicação caracteriza a própria inexistência do Peti e do PDTI, que só terão validade quando devidamente publicados no âmbito da Ufam, fato que não ocorreu durante a execução desta fiscalização. Assim, cabe determinação para que a instituição estabeleça seu planejamento estratégico de TI e plano diretor de TI.

Proposta de encaminhamento

52.10. Determinar à Fundação Universidade do Amazonas que:

52.10.1. em atenção ao art. 6º, inciso I, do Decreto-Lei 200/1967, e em consonância com o item 9.1.2 do Acórdão 1.233/2012-TCU-Plenário, estabeleça processo de planejamento estratégico de TI que contemple, pelo menos, as práticas descritas nos itens 9.1.2.1 a 9.1.2.6 do Acórdão 1.233/2012-TCU-Plenário;

52.10.2. em atenção ao art. 6º, inciso I, do Decreto-Lei 200/1967, institua formalmente o plano diretor de TI da Entidade, que deve ser aprovado pelo dirigente máximo da Instituição.

52.11. Recomendar à Fundação Universidade do Amazonas que, em consonância com o art. 6º, inciso I, do Decreto-Lei 200/1967, faça constar do plano diretor de TI pelo menos os seguintes elementos:

a) desdobramento das diretrizes estabelecidas em planos estratégicos, a exemplo do plano estratégico institucional e do plano estratégico de TI;

b) vinculação das ações de TI (atividades e projetos) a indicadores e metas de negócio;

c) vinculação das ações de TI a indicadores e metas de serviços ao cidadão;

d) vinculação entre as ações de TI priorizadas ao orçamento de TI;

e) quantitativo necessário (ideal) para a força de trabalho em TI.

6. Gestão de Pessoas de TI

53. Entre os elementos viabilizadores da governança e da gestão de TI apresentados no Cobit encontram-se as pessoas, em razão de sua elevada importância para a estruturação da TI. O tema tem sido objeto de reiterada preocupação desta Corte de Contas, que tem se manifestado a respeito da importância das instituições realizarem avaliações quantitativas e qualitativas do quadro de profissionais de TI disponíveis, de forma a fundamentar futuros pleitos de ampliação e preenchimento de vagas (Acórdãos 465/2011, 592/2011, 758/2011, 2.613/2011, todos do Plenário do TCU).

54. A carência de recursos humanos nas áreas de TI ganhou tal relevância que foi alçada a condição de destaque no Voto do Ministro-Substituto Augusto Sherman na apreciação das Contas de Governo, Exercício de 2012:

'destaco, nesta ocasião, a necessidade de a Administração Pública aprimorar a política de pessoal da área de TI. Isto porque, em essência, se a estrutura de pessoal estiver bem cuidada, a tendência natural é a paulatina resolução da maioria das fragilidades atinentes à governança de TI. E sem a incorporação à estrutura de pessoal do Estado brasileiro de bons gerentes de TI, dificilmente alcançaremos as melhorias pretendidas e necessárias, tanto na governança de TI quanto nas contratações públicas de TI.'

55. No mesmo sentido, a Estratégia-Geral de TI do Sisp definiu como uma das duas prioridades estratégicas para 2013: “Aprimorar a gestão de pessoas de TI”, reforçando a importância do assunto. Objetiva-se, em última instância, que as áreas de TI sejam providas dos profissionais necessários para que a TI desempenhe adequadamente sua missão institucional.

56. De forma a ilustrar a situação da remuneração dos recursos humanos que compõem a força de trabalho de TI na Universidade do Amazonas, foi enviado o Ofício de Requisição 386/2013-4/2013 (peça 6). Em resposta, a Ufam enviou a esta Unidade técnica o Ofício 612/2013/GR/Ufam (peça 9), do qual podem-se aduzir as seguintes informações:

56.1. A força de trabalho em tecnologia da informação da Ufam é composta de dezessete servidores de nível superior, treze servidores de nível médio, e dois empregados terceirizados. Suas remunerações médias são de R\$ 5.085,11, R\$ 4.189,63 e R\$ 4.702,92, respectivamente.

57. Ressalta-se que por ocasião do preenchimento do questionário utilizado no levantamento do perfil de governança de TI de 2012, a Fundação Universidade do Amazonas informou não possuir critérios definidos para a avaliação e atendimento aos pedidos de capacitação em gestão de TI.

6.1. Falha na gestão de recursos humanos em TI

58. Há insuficiência de recursos humanos em TI frente às necessidades identificadas pela Universidade do Amazonas.

Critérios

58.1. Item 9.2.2 do Acórdão 1233/2012-TCU-Plenário;

58.2. APO 07.01 - Manter equipe adequada e apropriada - Cobit 5;

58.3. APO 07 - Gerenciar Recursos Humanos.

Análise das evidências

58.4. Na minuta de reforma administrativa do CPD da Ufam (peça 22), consta estudo do quantitativo considerado ideal para compor a força de trabalho de TI da instituição, em compatibilidade com a demanda de serviços atendidos pela área de TI. De igual forma, é demonstrado que o quantitativo atual da Ufam está aquém do considerado ideal, com a carência de 27 analistas e sete técnicos para compor a força de trabalho em TI.

Causas

58.5. Nível de comprometimento insuficiente da instituição com as necessidades de alocação de recursos humanos na área de TI.

Efeitos e riscos decorrentes da manutenção da situação encontrada

58.6. Incapacidade de atender tempestivamente as demandas de negócio (efeito potencial).

58.7. Alta dependência tecnológica de fornecedores de soluções de TI (efeito potencial).

58.8. Atividades de gestão de TI executada por pessoal das empresas contratadas (efeito potencial).

Conclusão

58.9. Como aponta o estudo efetuado pela Ufam, existe a carência de pessoal para compor a força de trabalho em TI. Desta forma, cabe recomendação à Ufam para que envide esforços no sentido de dotar o setor de TI com o quantitativo ideal da força de trabalho.

Proposta de encaminhamento

58.10. Recomendar à Fundação Universidade do Amazonas que, tendo em vista o resultado da avaliação do pessoal do setor de TI da Entidade, envide esforços no sentido de dotar esse setor com o quantitativo de pessoal adequado para suprir as necessidades de trabalho em TI, à semelhança das orientações contidas no Cobit 5, Prática de Gestão APO07.01 – *Maintain adequate and appropriate staffing* (Manter pessoal adequado e apropriado – tradução livre).

7. Processos

59. A dimensão de processos do perfil de governança de TI compreende uma série de atividades sobre as quais estrutura-se a gestão da TI. Nesse contexto, foram avaliados os processos ligados à gestão dos serviços de TI oferecidos, da segurança da informação, incluindo a garantia de continuidade dos serviços de TI e gestão sobre os incidentes de segurança; ao planejamento e à gestão das contratações.

60. A gestão de serviços de TI objetiva garantir que os serviços sejam prestados em conformidade com as expectativas e necessidades da organização. Os processos de gestão de serviços, conforme definidos na NBR ISO/IEC 20000-2, compreendem diversos aspectos relacionados ao fornecimento dos serviços, tais como a organização de um catálogo de serviços de TI, o estabelecimento de acordos de níveis de serviço com as áreas de negócio, os mecanismos de monitoramento dos serviços e dos acordos pactuados.

61. Os processos de gestão da segurança da informação foram destacados em razão dos resultados apresentados nos três levantamentos de governança de TI, que ainda sinalizam, de forma geral, deficiências na forma como a APF gerencia a segurança de suas informações.

62. Inicia-se a avaliação da segurança da informação pela verificação da existência de uma política de segurança da informação (PSI) – instrumento basilar de organização da segurança da informação institucional. A existência de uma PSI da instituição é requisito expresso pelo art. 5º, inciso VII, da Instrução Normativa GSI/PR 1/2008 e no art. 13 da Resolução 90/2009 do CNJ, bem como pela ampla jurisprudência do TCU a respeito do tema.

63. Ainda, foram objeto de avaliação as estruturas organizacionais requeridas para organizar e conduzir a segurança da informação, além de uma série de outros aspectos abordados no perfil de governança, tais como gestão de continuidade, gestão de ativos, política de controle de acesso, ações de conscientização e treinamento, gestão de riscos e gestão de incidentes, todos no âmbito da segurança da informação.

64. Para a execução dos objetivos de negócio, as instituições normalmente necessitam realizar contratações de TI. Com efeito, os processos adotados para planejamento das contratações e gestão dos contratos firmados são um instrumento importante para a padronização dessas atividades na instituição, a organização de controles e a obtenção de melhores resultados com sua execução.

65. Nos itens 5.1 a 5.3 do questionário utilizado no levantamento do perfil de governança de TI de 2012, a Fundação Universidade do Amazonas assinalou não possuir os processos de gestão de serviços de TI listados no referido questionário. Informou também não possuir catálogo formal de serviços de TI. Por fim, indicou não possuir instrumentos relacionados à gestão da segurança da informação, a exemplo de política de segurança da informação (PSI), comitê de segurança da informação, equipe de tratamento e respostas a incidentes de redes, entre outros.

7.1. Falhas na gestão de nível de serviço

66. Não há um catálogo formal e atualizado de serviços de TI oferecidos aos clientes. Tampouco existem acordos de nível de serviço formais com as áreas de negócio clientes de TI.

Critérios

66.1. Norma Técnica – NBR ISO/IEC 20.000-2, item 6.1.2.

Análise das evidências

66.2. Em resposta enviada por meio do Ofício 449/2013/GR/Ufam (peça 7, p. 5), os gestores da Ufam informaram que seu catálogo de serviços de TI está disponível no endereço eletrônico <http://cpd.ufam.edu.br/serviços>. Entretanto, o conteúdo da página indicada contém apenas o nome do serviço e uma breve descrição. Assim, o catálogo não contém informações importantes, a exemplo daquelas previstas no item 6.1.1. da NBR ISO/IEC 20.000-2, como a denominação do responsável, pontos de contato, horários do serviço, exceções, entre outros. Também não existe um processo de revisão periódica desse catálogo. Por fim, verifica-se que a lista de serviços descritos na página supracitada não está completa, uma vez que são se encontra, por exemplo, o serviço de concessão de acesso a sistemas corporativos.

66.3. Sobre monitoramento dos níveis de serviço e estabelecimento de acordos de níveis de serviços, verifica-se que a resposta da Ufam remonta ao documento de proposta da reforma administrativa do CPD (peça 22) que, conforme já comentado, não passa de uma minuta, sem a adoção formal por parte da Ufam.

66.4. Por fim, confirmou-se por entrevista que não existem acordos formais de níveis de serviço com as áreas de negócio, que são clientes de TI. Tal constatação também é reforçada pelo fato do único documento apresentado como instrumento de gestão de nível de serviço, que foi o catálogo (peça 20), não conter qualquer menção a acordos de nível de serviço.

Causas

66.5. Nível de comprometimento da entidade insuficiente com a gestão de nível de serviço.

Efeitos e riscos decorrentes da manutenção da situação encontrada

66.6. Desconhecimento, por parte dos clientes de TI, dos serviços oferecidos pela área de TI (efeito potencial).

66.7. Aumento do risco de falhas na entrega dos serviços aos clientes internos da TI, de acordo com as prioridades do negócio e dentro do orçamento estabelecido.

Conclusão

66.8. A Universidade do Amazonas não dispõe de um catálogo dos serviços de TI formalmente aprovado e publicado, e tampouco, um processo de revisão constante no catálogo. Em adição, a Ufam não estabeleceu formalmente acordos de níveis de serviços com sua clientela, e não monitora o nível dos seus principais serviços. Desta forma, cabe recomendação para que a Entidade avalie a conveniência e oportunidade de estabelecer estes elementos de governança de TI.

Proposta de encaminhamento

66.9. Recomendar à Fundação Universidade do Amazonas que:

66.9.1. avalie a conveniência e a oportunidade de implementar processo de gestão de nível de serviço de TI, de forma a assegurar que níveis adequados de serviço sejam entregues para os clientes internos de TI, de acordo com as prioridades do negócio e dentro do orçamento estabelecido, à semelhança das orientações contidas na seção 6.1.3 da ABNT NBR ISO/IEC 20.000-2:2008;

66.9.2. elabore, publique e mantenha atualizado catálogo de serviços de TI da Entidade, à semelhança das orientações contidas no Cobit 5, Prática de Gestão APO9.02 – *Catalogue IT-enabled services* (Catalogar serviços de tecnologia da informação habilitados – tradução livre).

7.2. Falha em processos de gestão de segurança da informação

67. A Universidade do Amazonas não possui os seguintes controles e processos de governança de TI, ligados à gestão de segurança da informação: gestão de continuidade de negócio, política de controle de acesso à informação, processo de gestão de riscos de segurança

da informação, e programa de conscientização e treinamento em segurança da informação. A Ufam também não dispõe de inventário de seus ativos de informação.

Critérios

- 67.1. Norma Técnica – NBR ISO/IEC 15.999, item 8.7.2;
- 67.2. Norma Técnica – NBR ISO/IEC 27.002:2005, item 14.1.3;
- 67.3. Norma Complementar 6/GSI/PR, item 6;
- 67.4. Norma Complementar 7/GSI/PR, item 2.6;
- 67.5. Norma Complementar 2/IN01/DSIC/GSIPR, item 3.2.5;
- 67.6. Norma Complementar 4/GSI/PR.
- 67.7. Acórdão 2.938/2010, Tribunal de Contas da União, Plenário;
- 67.8. Acórdão 380/2011, Tribunal de Contas da União, Plenário;
- 67.9. Acórdão 436/2008, Tribunal de Contas da União, Plenário;
- 67.10. Acórdão 1.609/2012, Tribunal de Contas da União, Plenário;
- 67.11. Acórdão 2.523/2012, Tribunal de Contas da União, Plenário;

Análise das evidências

67.12. Verificou-se por meio de entrevista com os gestores da Ufam, que não existe na instituição um processo de gestão de continuidade de serviços de TI formalmente aprovado e publicado.

67.13. Em relação ao inventário de ativos de informação, os gestores da Unidade enviaram documento constante à peça 16. Tal documento é um relatório gerado a partir de uma ferramenta de TI (Centreon), e contém apenas algumas informações básicas sobre máquinas servidoras e *switches* (denominação, descrição, endereço ip, *status*). Não consta no citado relatório, entre outros itens, o inventário de software. Ademais, mesmo para os ativos constantes no relatório, não estão descritas informações importantes, como localização e importância do ativo para a organização. Desta forma, considera-se que o documento enviado não se caracteriza como um inventário de ativos de informação, tomando-se como padrão o estabelecido no item 7.1.1 na NBR ISO/IEC 27.002.

67.14. Demandados sobre a política de controle de acesso, os gestores da Ufam apresentaram a minuta de uma política de segurança da informação, constante à peça 21. Este documento trata especificamente da segurança da informação, e não determina a política de controle de acesso. São políticas distintas. Desta forma, verifica-se que a instituição não possui política de controle de acesso.

67.15. Conforme resposta apresentada no Ofício 449/2013/GR/Ufam (peça 7), não houve ações de conscientização e treinamento sobre segurança da informação, nos anos de 2010 e 2011. Segundo os gestores, existe a previsão de se executar tais ações quando tiverem o escritório de segurança da informação.

67.16. Por fim, os gestores informaram não terem sido realizadas ações para a análise de riscos em segurança da informação. Existe apenas a previsão, mas que depende da implantação do escritório de segurança da informação (peça 7, p. 5)

Causas

67.17. Falha no estabelecimento de políticas de governança de TI.

Efeitos e riscos decorrentes da manutenção da situação encontrada

67.18. Aumento do risco de incidentes de segurança da informação (efeito potencial).

Conclusão

67.19. Cabe determinação à Fundação Universidade do Amazonas, para que implemente mecanismos de gestão de segurança da informação, relacionados à gestão de continuidade de negócio, política de controle de acesso à informação, processo de gestão de riscos de segurança da informação, e programa de conscientização e treinamento em segurança da informação. De igual forma, determinar-lhe para que realize inventário de seus ativos de informação. Por fim, cabe recomendação para que elabore e execute processo de gestão de continuidade dos serviços de TI.

Proposta de encaminhamento

67.20. Recomendar à Fundação Universidade do Amazonas que elabore e execute processo de gestão de continuidade dos serviços de TI, à semelhança das orientações contidas no Cobit 5, DSS04.3 – *Develop and implement a business continuity response* (Desenvolver e implementar resposta à continuidade do negócio – tradução livre).

67.21. Determinar à Fundação Universidade do Amazonas que:

67.21.1. em atenção às disposições contidas na NC – DSIC/GSI/PR 6/IN01, de 11 de novembro de 2009, e em consonância com o item 9.2 do Acórdão 1.603/2008-TCU-Plenário, elabore, execute e teste periodicamente o plano de gestão de continuidade do negócio da Instituição, de forma a minimizar os impactos decorrentes de falhas, desastres ou indisponibilidades significativas sobre as atividades da Entidade, à semelhança das orientações contidas na seção 14 da ABNT NBR ISO/IEC 27.002:2005, nas seções 8.6 e 8.7 da ABNT NBR 15999-1:2007 e no Cobit 5, DSS04.3 – *Develop and implement a business continuity response* (Desenvolver e implementar resposta à continuidade do negócio – tradução livre);

67.21.2. em atenção ao item 2.6 da NC – DSIC/GSI/PR 7/IN01, de 6 de maio de 2010, e em consonância com o item 9.2 do Acórdão 1.603/2008-TCU-Plenário, elabore e aprove formalmente a política de controle de acesso a informações e recursos de TI, com base nos requisitos de negócio e de segurança da informação da Entidade, à semelhança das orientações contidas na seção 11.1.1 da ABNT NBR ISO/IEC 27.002:2005;

67.21.3. em atenção ao disposto na NC – DSIC/GSI/PR 10/IN01, de 30 de janeiro de 2012, elabore e execute processo de gestão de ativos de informação da Entidade, à semelhança das orientações contidas na seção 7.1 da ABNT NBR ISO/IEC 27.002:2005 e no Cobit 5, Processo BAI09 – *Manage assets* (Gerenciar ativos – tradução livre).

67.21.4. em atenção ao disposto na seção 3.2.5 da NC – DSIC/GSI/PR 2/IN01, 13 de outubro de 2008, implante programas de conscientização e treinamento em segurança da informação, à semelhança das orientações contidas na seção 8.2.2 da ABNT NBR ISO/IEC 27.002:2005;

67.21.5. em atenção ao disposto na NC – DSIC/GSI/PR 4/IN01, de 15 de fevereiro de 2013, elabore e implemente processo de gestão de riscos de segurança da informação, à semelhança das orientações contidas na seção 4 da ABNT NBR ISO/IEC 27.002:2005.

7.3. Inexistência de política de segurança da informação e comunicações

68. A Universidade do Amazonas não possui uma política de segurança da informação e comunicações.

CrITÉRIOS

68.1. Instrução Normativa GSI/PR 1/2008, art. 5º, inciso VII.

Análise das evidências

68.2. De acordo com a resposta constante no Ofício 449/2013/GR/Ufam (peça 7), a Universidade não possui política de segurança da informação e comunicações. Existe uma minuta, constante à peça 21, que foi enviada à Reitoria da Ufam, em 8/1/2013 (peça 12), mas que ainda não foi aprovada.

Causas

68.3. A instituição não compreende satisfatoriamente a segurança da informação como tema importante para o alcance dos objetivos de negócio.

Efeitos e riscos decorrentes da manutenção da situação encontrada

68.4. Aumento do risco de incidentes de segurança da informação (efeito potencial).

Conclusão

68.5. Cabe determinação à Fundação Universidade do Amazonas, para que elabore e aprove uma política de segurança da informação e comunicações, pois trata-se de instrumento cogente no âmbito do executivo federal, nos termos ao art. 5º, inciso VII, da IN GSI/PR 1/2008.

Proposta de encaminhamento

68.6. Determinar à Fundação Universidade do Amazonas que, em atenção ao art. 5º, inciso VII, da IN – GSI/PR 1/2008, elabore e aprove formalmente a política de segurança da informação e comunicações da Entidade, que deve contemplar, em especial, os elementos estabelecidos no item 5.3 da NC – DSIC/GSI/PR 3/IN01, 30 de junho de 2009, e na seção 5.1.1 da ABNT NBR ISO/IEC 27.002:2005.

7.4. Falhas na alocação de responsabilidades pela segurança da informação

69. A Universidade do Amazonas não possui um comitê de segurança da informação. Também não designou responsável pela segurança da informação. Adicionalmente, não tem equipe de tratamento e resposta a incidentes em redes computacionais.

Critérios

69.1. Instrução Normativa GSI/PR 1/2008, art. 5º, incisos IV, V e VI;

Análise das evidências

69.2. Da análise das respostas constantes no Ofício 449/2013/GR/Ufam (peça 7), pode-se aduzir que a Fundação Universidade do Amazonas não possui um comitê de segurança da informação. Tampouco designou formalmente um responsável pela segurança da informação. De igual forma, não foi designada formalmente equipe de tratamento e resposta a incidentes em redes computacionais.

69.3. A Ufam apresentou minuta de criação de comissão de segurança da informação, constante à peça 19. Contudo, tal comissão não se encontra formalizada. Quanto às responsabilidades pela segurança da informação e de tratamento de incidentes, existe a previsão destas atribuições na minuta de reforma do CPD da instituição (peça 22), que também não foi formalizado até a execução desta auditoria.

69.4. Ressalte-se que os gestores informaram, em reunião, que existe uma equipe alocada para a formação de um escritório de segurança da informação. Todavia, entende-se que a inexistência de um comitê gestor de segurança da informação formalmente instituído, além da não designação formal das responsabilidades pela segurança da informação, fragiliza o trabalho da equipe designada, pois carece respaldo à sua atuação.

Causas

69.5. Nível de comprometimento insuficiente da instituição com a gestão de segurança da informação.

Efeitos e riscos decorrentes da manutenção da situação encontrada

69.6. Aumento do risco de incidentes de segurança da informação (efeito potencial);

69.7. Tratamento inadequado ou inexistente aos incidentes em redes computacionais (efeito potencial).

Conclusão

69.8. Cabe determinação à Fundação Universidade do Amazonas, para que constitua comitê gestor de segurança da informação, designe responsável pela segurança da informação e institua equipe de tratamento e resposta a incidentes em redes computacionais.

Proposta de encaminhamento

69.9. Determinar à Fundação Universidade do Amazonas que:

69.9.1. em atenção ao art. 5º, inciso VI, da IN – GSI/PR 1/2008 c/c o item 5.3.7.3 da NC – DSIC/GSI/PR 3/IN01, de 30 de junho de 2009, institua comitê gestor de segurança da informação e comunicações, à semelhança das orientações contidas no item 6.1.2 da ABNT NBR ISO/IEC 27.002:2005;

69.9.2. em atenção ao art. 5º, inciso IV, da IN – GSI/PR 1/2008 c/c o item 5.3.7.2 da NC – DSIC/GSI/PR 3/IN01, de 30 de junho de 2009, designe formalmente responsável pela segurança da informação e comunicações da Entidade, à semelhança das orientações contidas no item 6.1.3 da ABNT NBR ISO/IEC 27.002:2005;

69.9.3. em atenção ao art. 5º, inciso V, da IN – GSI/PR 1/2008 e às disposições contidas na NC – DSIC/GSI/PR 5/IN01, de 14 de agosto de 2009, institua formalmente equipe de tratamento e resposta a incidentes em redes computacionais, à semelhança das orientações contidas na seção 13 da ABNT NBR ISO/IEC 27.002:2005.

7.5. Falhas na gestão de incidentes de segurança da informação

70. A Universidade do Amazonas não possui um processo de gestão de incidentes de segurança da informação. De igual forma, não designou formalmente unidade ou equipe de gestão de incidentes de segurança da informação.

Critérios

70.1. Acórdão 758/2011, item 9.1.9., Tribunal de Contas da União, Plenário;

70.2. Acórdão 380/2011, Tribunal de Contas da União, Plenário;

70.3. Acórdão 2.613/2011, item 9.1.8., Tribunal de Contas da União, Plenário;

70.4. Norma Complementar 2/GSI/PR, item 3.2.7.;

Análise das evidências

70.5. Em resposta a questionamento sobre existência de processo de gestão de incidentes de segurança da informação, a Ufam apresentou relatório *Alarms Report* produzido pela ferramenta *Alien Vault*, constante à peça 10. Sobre a existência de equipe ou unidade formalmente designada para a gestão de incidentes de segurança da informação, os gestores informaram que possuem uma estrutura de escritório de segurança da informação, mas que não é formalizada oficialmente (peça 7).

70.6. O relatório *Alarms Report* indica *hosts* que efetuaram ataques à Ufam, além dos *hosts* da instituição que mais sofreram ataque. Contudo, este relatório não pode ser considerado um processo institucional de gestão de incidentes. Apenas indica que a Ufam possui uma ferramenta que cataloga um tipo específico de incidente de segurança de informação, que são os ataques de *hosts* externos.

70.7. Desta forma, verifica-se que a Ufam não dispõe de processo de gestão de incidentes, nem equipe formalmente designada para tal função.

Causas

70.8. Nível de comprometimento insuficiente da instituição com a gestão de incidentes em segurança da informação.

Efeitos e riscos decorrentes da manutenção da situação encontrada

70.9. Tratamento inadequado ou inexistente aos incidentes de segurança da informação (efeito potencial).

Conclusão

70.10. Cabe determinação para que à Universidade elabore e execute processo de gestão de incidentes de segurança da informação, bem como institua formalmente equipe específica para tratar dos incidentes dessa natureza.

Proposta de encaminhamento

70.11. Determinar à Fundação Universidade do Amazonas que, em atenção ao item 3.2.7 da NC – DSIC/GSI/PR 2/IN01, de 13 de outubro de 2008, elabore e execute processo de gestão de incidentes de segurança da informação, bem como institua formalmente equipe específica para tratar dos incidentes dessa natureza, à semelhança das orientações contidas na seção 13 da ABNT NBR ISO/IEC 27002:2005.

7.6. Falhas no planejamento das contratações de TI

71. A Universidade do Amazonas não possui processo de planejamento das contratações de tecnologia da informação.

CrITÉRIOS

71.1. Guia de boas práticas em contratação de soluções de TI, item 5.8. Tribunal de Contas da União;

71.2. IN SLTI/MP 4/2010;

Análise das evidências

71.3. Da análise das respostas constantes no Ofício 449/2013/GR/Ufam (peça 7), pode-se aduzir que a Universidade não tem processo de planejamento de contratação de soluções de tecnologia da informação. Afirmaram que, em sua reforma de proposta administrativa do CPD, tal atribuição deverá ser exercida pelo escritório de projetos.

71.4. Corroborar tal constatação a resposta da Ufam ao item 5.8. do questionário utilizado no levantamento do perfil de governança de TI de 2012, onde a instituição afirma que as contratações de TI são realizadas à medida que as demandas vão surgindo. Ademais, em entrevista com os gestores, foi noticiado que as demandas de TI são decididas diretamente entre o gestor do CPD e representantes da alta administração, uma vez que o comitê de TI não vem atuando.

Causas

71.4. Baixa maturidade da instituição em contratações de soluções de tecnologia da informação.

Efeitos e riscos decorrentes da manutenção da situação encontrada

71.5. Contratações não planejadas para atender as necessidades de negócio da instituição (efeito potencial).

Conclusão

71.6. Cabe recomendação à Universidade do Amazonas, para que defina processo formal de contratação de soluções de TI.

Proposta de encaminhamento

71.7. Recomendar à Fundação Universidade do Amazonas que, em consonância com o item 9.2.9.9 do Acórdão 1.233/2012-TCU-Plenário, implante formalmente processo de contratação de soluções de TI, adequando o processo definido na IN – SLTI/MP 4/2010 ao contexto da Entidade.

7.7. Falhas na gestão das contratações de TI

72. A Fundação Universidade do Amazonas não possui um processo de gestão de contratos de soluções de tecnologia da informação.

Critérios

72.1. Guia de boas práticas em contratação de soluções de TI, item 5.8. Tribunal de Contas da União;

72.2. IN SLTI/MP 4/2010;

72.3. Acórdão 1.233/2009, item 9.11.10., Tribunal de Contas da União, Plenário;

Análise das evidências

72.4. Em resposta constante no Ofício 449/2013/GR/Ufam (peça 7), os gestores apresentaram uma portaria de designação de fiscal de um determinado contrato (peça 25). Em entrevista, afirmaram não possuir um processo estabelecido de gestão de contratos de solução de TI, mas asseveraram que a portaria de designação apresentada é usada como modelo para a designação de fiscais de outros contratos. Contudo, verifica-se que não há, de fato, um processo formalizado que garanta requisitos mínimos de atuação nas fiscalizações de contratos de soluções de TI.

Causas

72.5. Falha no estabelecimento de políticas de governança de TI.

Efeitos e riscos decorrentes da manutenção da situação encontrada

72.6. Falhas no processo de fiscalização dos contratos de soluções de TI (efeito potencial).

Conclusão

72.7. Cabe recomendação à Universidade do Amazonas, para que defina um processo de gestão de contratos de soluções de TI e o implante no âmbito da instituição.

Proposta de encaminhamento

72.8. Recomendar à Fundação Universidade do Amazonas que, em consonância com o item 9.2.9.9 do Acórdão 1.233/2012-TCU-Plenário, implante processo de gestão de contratos de soluções de TI, adequando o processo definido na IN – SLTI/MP 4/2010 ao contexto da Entidade.

8. Análise dos comentários do gestor

73. Nos termos do Manual de Auditoria Operacional, aprovado pela Portaria Segecex/TCU 4, de 26/2/2010, a versão preliminar do relatório de auditoria foi remetida à Fundação Universidade do Amazonas, por meio do Ofício 1794/2013-TCU/Secex-AM, de 9/10/2013 (peça 26), com a finalidade de se obter os comentários dos gestores sobre as conclusões da fiscalização, de modo a conferir melhor compreensão das questões abordadas, das oportunidades de melhoria identificadas e das recomendações propostas.

74. Os gestores da referida entidade não enviaram resposta a esta Unidade Técnica.

9. Conclusão

75. Ante todas as análises realizadas, pode-se deduzir que praticamente não existem ações de governança de tecnologia da informação na Fundação Universidade do Amazonas, e as que existem, são incipientes. A ação de maior impacto, que foi a criação de um comitê de TI,

ficou resumida a seu ato de instituição, pois tal comitê não atua na prática, mesmo com previsão de reuniões mensais.

76. Verificou-se que a alta administração da Fundação Universidade do Amazonas não estabeleceu algumas das principais políticas corporativas, em especial a política de segurança da informação. Desta forma, os usuários de TI da Ufam não contam com diretrizes para guiar a correta utilização dos recursos de tecnologia da informação. Existem algumas minutas, como a que institui a política de segurança da informação (peça 21), e a que constitui a comissão de segurança da informação (peça 19), mas que ainda não foram aprovadas e implementadas.

77. Quanto ao planejamento estratégico de TI, observou-se que não há um processo alinhado ao planejamento estratégico institucional. Apesar do setor responsável pela administração dos recursos de TI ter formulado e estar seguindo um planejamento próprio, verificou-se que não existem mecanismos que garantam o alinhamento deste plano com o plano estratégico institucional (PEI), e tampouco envolvimento da alta administração neste planejamento, uma vez que a Ufam não conta com Peti ou PDTI aprovados formalmente.

78. No que concerne à gestão de recursos humanos em TI, constatou-se a carência de pessoal na referida área, o que pode comprometer o alcance dos resultados institucionais, além da dependência tecnológica de empresas terceirizadas.

79. Desta forma, verifica-se que a alta administração da Universidade não tem envidado esforços necessários para o estabelecimento de políticas de governança de TI, aumentando, desta forma, os riscos de que os recursos financeiros direcionados a esta área não tenham uma eficiente aplicação, pouco contribuindo para o alcance das metas institucionais.

80. Um dos objetivos secundários da fiscalização em tela era a verificação de eventuais inconsistências entre as evidências de implementação dos controles de TI e as respostas apresentadas pelos órgãos e entidades no levantamento do perfil de governança de TI de 2012. Pretende-se, assim, subsidiar o aperfeiçoamento do instrumento de levantamento e de avaliação de governança de TI.

81. Ressalte-se que as inconsistências relatadas têm causas diversas, tais como: falhas de interpretação do questionário por parte do ente fiscalizado; falta de clareza de algumas perguntas do questionário; grau de rigor empregado pela instituição na autoavaliação. As inconsistências apresentadas ao longo da exposição dos achados de auditoria estão resumidas no quadro abaixo:

Seção	Resposta apresentada no Perfil GovTI2012	Situação encontrada (referência aos parágrafos)
1.2	A alta administração se responsabiliza pela avaliação e pelo estabelecimento das políticas de governança, gestão e uso corporativos de TI.	A alta administração não estabeleceu políticas corporativas, tais como política de segurança da informação e política de governança de TI (parágrafo 32)
1.2	A alta administração designou representantes de todas as áreas relevantes para o negócio institucional para compor o Comitê de TI.	O comitê de TI não tem, em sua composição, representantes das principais áreas do negócio (parágrafo 40)
1.2	A alta administração avalia e monitora o cumprimento das políticas de governança, gestão e uso corporativos de TI.	Não há instituição de tais políticas, logo não há monitoramento. (parágrafo 41)
1.3	A alta administração estabeleceu objetivos de gestão e uso corporativo de TI	Não foram estabelecidos alguns mecanismos importantes para a alta administração dirigir e avaliar a gestão e o uso corporativo de TI (parágrafo 42)
1.3	A alta administração estabeleceu metas de desempenho da gestão e do uso corporativos de TI, para 2012	Não foram estabelecidas metas de desempenho da gestão e do uso corporativos de TI, para 2012 (parágrafo 42)

Seção	Resposta apresentada no Perfil GovTI2012	Situação encontrada (referência aos parágrafos)
2.2	A instituição executa um processo periódico de planejamento estratégico de TI, embora este não esteja formalmente instituído.	Não existe um processo formal de planejamento estratégico de TI (parágrafos 51 e 52)
2.2	A elaboração do PDTI conta com a participação das áreas de negócio, e o PDTI é elaborado com o apoio do comitê de TI.	Não foi elaborado um PDTI (parágrafos 51 e 52)

82. Dentre os questionamentos apresentados, constatou-se junto aos gestores entrevistados que as inconsistências apresentadas acima não decorreram de dificuldades no entendimento das questões. Assim, as inconsistências constituem situações em que as evidências apresentadas não foram consideradas suficientes pela equipe de auditoria para respaldar a resposta apresentada.

10. Benefícios das Ações de Controle Externo

83. Entre os benefícios desta auditoria pode-se mencionar o benefício direto de incremento da economia, eficiência, eficácia ou efetividade de órgão ou entidade da administração pública, indicado no item 42.4 das orientações para benefícios de controle, constantes do anexo da Portaria-Segecex 10, de 30/3/2012.

11. Proposta de Encaminhamento

84. Ante todo o exposto, submetem-se os autos à consideração superior, para posterior envio ao gabinete do Ministro-Relator, com a seguinte proposta:

85. Determinar, com fulcro no art. 43, inciso I, da Lei 8.443/1992 c/c o art. 250, inciso II, do Regimento Interno do TCU, à Fundação Universidade do Amazonas que:

85.1. em atenção ao art. 7º, inciso II, alínea “d” do Decreto 6.029/2007, dê ampla divulgação do código de ética, incluindo mecanismos que garantam o fácil acesso deste por parte de seus servidores, como por exemplo, divulgação em sua intranet;

85.2. em atenção ao art. 6º, inciso I, do Decreto-Lei 200/1967, e em consonância com o item 9.1.2 do Acórdão 1.233/2012-TCU-Plenário, estabeleça processo de planejamento estratégico de TI que contemple, pelo menos, as práticas descritas nos itens 9.1.2.1 a 9.1.2.6 do Acórdão 1.233/2012-TCU-Plenário;

85.3. em atenção ao art. 6º, inciso I, do Decreto-Lei 200/1967, institua formalmente o plano diretor de TI da entidade, que deve ser aprovado pelo dirigente máximo da Instituição;

85.4. em atenção ao art. 5º, inciso VII, da IN – GSI/PR 1/2008, elabore e aprove formalmente a política de segurança da informação e comunicações da Entidade, que deve contemplar, em especial, os elementos estabelecidos no item 5.3 da NC – DSIC/GSI/PR 3/IN01, 30 de junho de 2009, e na seção 5.1.1 da ABNT NBR ISO/IEC 27.002:2005;

85.5. em atenção ao art. 5º, inciso VI, da IN – GSI/PR 1/2008 c/c o item 5.3.7.3 da NC – DSIC/GSI/PR 3/IN01, de 30 de junho de 2009, institua comitê gestor de segurança da informação e comunicações da Entidade, à semelhança das orientações contidas no item 6.1.2 da ABNT NBR ISO/IEC 27.002:2005;

85.6. em atenção ao art. 5º, inciso IV, da IN – GSI/PR 1/2008 c/c o item 5.3.7.2 da NC – DSIC/GSI/PR 3/IN01, de 30 de junho de 2009, designe formalmente responsável pela segurança da informação e comunicações da Entidade, à semelhança das orientações contidas no item 6.1.3 da ABNT NBR ISO/IEC 27.002:2005;

85.7. em atenção ao art. 5º, inciso V, da IN – GSI/PR 1/2008 e às disposições contidas na NC – DSIC/GSI/PR 5/IN01, de 14 de agosto de 2009, institua formalmente equipe de tratamento e resposta a incidentes em redes computacionais, à semelhança das orientações contidas na seção 13 da ABNT NBR ISO/IEC 27.002:2005;

85.8. em atenção às disposições contidas na NC–DSIC/GSI/PR 6/IN01, de 11 de novembro de 2009, e em consonância com o item 9.2 do Acórdão 1.603/2008-TCU-Plenário, elabore, execute e teste periodicamente o plano de gestão de continuidade do negócio da Instituição, de forma a minimizar os impactos decorrentes de falhas, desastres ou indisponibilidades significativas sobre as atividades da Entidade, à semelhança das orientações contidas na seção 14 da ABNT NBR ISO/IEC 27.002:2005, nas seções 8.6 e 8.7 da ABNT NBR 15999-1:2007 e no Cobit 5, DSS04.3 – *Develop and implement a business continuity response* (Desenvolver e implementar resposta à continuidade do negócio – tradução livre);

85.9. em atenção ao disposto na NC–DSIC/GSI/PR 10/IN01, de 30 de janeiro de 2012, elabore e execute processo de gestão de ativos de informação da Entidade, à semelhança das orientações contidas na seção 7.1 da ABNT NBR ISO/IEC 27.002:2005 e no Cobit 5, Processo BAI09 – *Manage assets* (Gerenciar ativos – tradução livre);

85.10. em atenção ao item 2.6 da NC–DSIC/GSI/PR 7/IN01, de 6 de maio de 2010, e em consonância com o item 9.2 do Acórdão 1.603/2008-TCU-Plenário, elabore e aprove formalmente a política de controle de acesso a informações e recursos de TI, com base nos requisitos de negócio e de segurança da informação da Entidade, à semelhança das orientações contidas na seção 11.1.1 da ABNT NBR ISO/IEC 27.002:2005;

85.11. em atenção ao disposto na seção 3.2.5 da NC–DSIC/GSI/PR 2/IN01, 13 de outubro de 2008, implante programas de conscientização e treinamento em segurança da informação na Entidade, à semelhança das orientações contidas na seção 8.2.2 da ABNT NBR ISO/IEC 27.002:2005;

85.12. em atenção ao disposto na NC–DSIC/GSI/PR 4/IN01, de 15 de fevereiro de 2013, elabore e implemente processo de gestão de riscos de segurança da informação, à semelhança das orientações contidas na seção 4 da ABNT NBR ISO/IEC 27.002:2005;

85.13. em atenção ao item 3.2.7 da NC–DSIC/GSI/PR 2/IN01, de 13 de outubro de 2008, elabore e execute processo de gestão de incidentes de segurança da informação, bem como institua formalmente equipe específica para tratar dos incidentes dessa natureza, à semelhança das orientações contidas na seção 13 da ABNT NBR ISO/IEC 27.002:2005;

85.14. no prazo de 60 (sessenta) dias a contar da ciência do acórdão que vier a ser proferido, encaminhe ao TCU plano de ação contemplando cronograma de implementação das determinações e recomendações contidas no *decisum*, contendo:

85.14.1. prazo e o responsável (nome, cargo e CPF) pelo desenvolvimento de cada ação;

85.14.2. para cada recomendação cuja implementação não seja considerada conveniente ou oportuna, justificativa da decisão e medidas alternativas que serão adotadas.

86. Recomendar, com fulcro no art. 250, inciso III, do Regimento Interno do TCU, à Fundação Universidade do Amazonas que:

86.1. com base nas boas práticas contidas na seção 2.3 do Código das Melhores Práticas de Governança Corporativa do IBGC, sensibilize os membros da alta administração acerca de sua responsabilidade em estabelecer e monitorar as políticas corporativas do órgão, a exemplo da política de segurança da informação e das demais políticas relativas à governança de tecnologia da informação;

86.2. elabore e aprove formalmente um processo de aprimoramento contínuo da governança de TI, a exemplo das boas práticas contidas no capítulo 3 do guia de referência da implementação do Cobit 5, que contemple pelo menos o seguinte:

a) definição de papéis e responsabilidades voltadas especificamente para a melhoria da governança de TI;

b) realização de diagnósticos ou autoavaliações de governança e de gestão de TI;

c) definição e acompanhamento de metas de governança de TI e das ações necessárias para alcançá-las, com base em parâmetros de governança, necessidades de negócio e riscos relevantes;

86.3. em atenção à iniciativa estratégica 3.1 da Estratégia Geral de TI, de 2013-2015, do Sisp, e em consonância com o disposto no item 9.2.1 do Acórdão 1.233/2012-TCU-Plenário, aperfeiçoe a implementação do Comitê de Tecnologia da Informação no sentido de assegurar o seu funcionamento permanente, bem como a efetiva alocação de representantes de áreas relevantes para o negócio da entidade, em especial representantes das áreas de ensino e pesquisa, que constituem o negócio da entidade, à semelhança das orientações contidas no Cobit 5, Prática de Gestão APO01.01 – *Define the organisational structure* (Definir a estrutura organizacional – tradução livre), atividades 7 e 8;

86.4. em consonância com o disposto no item 9.1.1 do Acórdão 2.308/2010-TCU-Plenário e com base nas boas práticas contidas na seção 3.3 da ABNT NBR ISO/IEC 38500:2009, estabeleça formalmente:

- a) objetivos de gestão e de uso corporativos de TI alinhados às estratégias de negócio;
- b) indicadores de desempenho para os objetivos de gestão definidos;
- c) metas de desempenho da gestão e do uso corporativos de TI para cada indicador definido;
- d) mecanismos para que a alta administração acompanhe o desempenho da TI da Instituição;
- e) mecanismos de gestão dos riscos relacionados aos objetivos de gestão e de uso corporativos de TI;

86.5. em consonância com o disposto no item 9.1.1 do Acórdão 2.308/2010-TCU-Plenário e com base nas boas práticas contidas na seção 3.3 da ABNT NBR ISO/IEC 38.500:2009, aprove formalmente o plano anual de auditoria interna da instituição, que deverá conter, entre outras atividades, ações com o objetivo de fornecer avaliação objetiva à alta administração quanto é eficácia do gerenciamento de riscos;

86.6. em consonância com o disposto no item 9.10.2 do Acórdão 1.233/2012-TCU-Plenário, realize auditorias periódicas na área de tecnologia da informação da Entidade, em especial no que diz respeito à avaliação da governança de TI, dos sistemas de informação e de suas bases de dados, da segurança da informação e das aquisições de bens e serviços de TI;

86.7. em consonância com o art. 6º, inciso I, do Decreto-Lei 200/1967, faça constar do plano diretor de TI pelo menos os seguintes elementos:

- a) desdobramento das diretrizes estabelecidas em planos estratégicos, a exemplo do plano estratégico institucional e do plano estratégico de TI;
- b) vinculação das ações de TI (atividades e projetos) a indicadores e metas de negócio;
- c) vinculação das ações de TI a indicadores e metas de serviços ao cidadão;
- d) vinculação entre as ações de TI priorizadas ao orçamento de TI;
- e) quantitativo necessário (ideal) para a força de trabalho em TI;

86.8. tendo em vista o resultado da avaliação do pessoal do setor de TI da Entidade, envide esforços no sentido de dotar esse setor com o quantitativo de pessoal adequado para suprir as necessidades de trabalho em TI, à semelhança das orientações contidas no Cobit 5, Prática de Gestão APO07.01 – *Maintain adequate and appropriate staffing* (Manter pessoal adequado e apropriado – tradução livre);

86.9. avalie a conveniência e a oportunidade de implementar processo de gestão de nível de serviço de TI, de forma a assegurar que níveis adequados de serviço sejam entregues para os clientes internos de TI, de acordo com as prioridades do negócio e dentro do orçamento

estabelecido, à semelhança das orientações contidas na seção 6.1.3 da ABNT NBR ISO/IEC 20.000-2:2008;

86.10. elabore, publique e mantenha atualizado catálogo de serviços de TI da Entidade, à semelhança das orientações contidas no Cobit 5, Prática de Gestão APO09.02 – *Catalogue IT-enabled services* (Catalogar serviços de tecnologia da informação habilitados – tradução livre);

86.11. elabore e execute processo de gestão de continuidade dos serviços de TI, à semelhança das orientações contidas no Cobit 5, DSS04.3 – *Develop and implement a business continuity response* (Desenvolver e implementar resposta à continuidade do negócio – tradução livre);

86.12. em consonância com o item 9.2.9.9 do Acórdão 1.233/2012-TCU-Plenário, implante formalmente processo de contratação de soluções de TI, adequando o processo definido na IN – SLTI/MP 4/2010 ao contexto da Entidade;

86.13. em consonância com o item 9.2.9.9 do Acórdão 1.233/2012-TCU-Plenário, implante processo de gestão de contratos de soluções de TI, adequando o processo definido na IN – SLTI/MP 4/2010 ao contexto da Entidade.

87. Autorizar, desde já, a realização de monitoramento do cumprimento das determinações e recomendações expedidas neste Acórdão."

É o relatório.

Proposta de Deliberação

Tratam os autos de auditoria integrante do conjunto de auditorias da primeira fase do trabalho de fiscalização de governança de tecnologia da informação (TI) com foco na avaliação da entrega de resultados e na gestão de riscos, realizado na sistemática de fiscalização de orientação centralizada (FOC).

2. Para responder às questões de auditoria formuladas com o fito de aferir a aderência do órgão/entidade às melhores práticas de governança e de gestão de TI, foi avaliada pela equipe de auditoria, no tocante à governança corporativa, a atuação da alta administração e do comitê de direção estratégica quanto ao estabelecimento e ao monitoramento de políticas corporativas, bem como aspectos relacionados à existência, à aplicação e à disseminação do código de ética.

3. No que diz respeito à governança de TI, foi verificado se: (i) foram definidas políticas e diretrizes de governança, gestão e uso de TI aptas a propiciar aprimoramento contínuo da governança de TI na instituição; (ii) foram definidos papéis e responsabilidades quanto à gestão e ao uso corporativo de TI, no sentido de se atingir os objetivos organizacionais; (iii) foram estabelecidas diretrizes para avaliar a gestão, o uso corporativo e o desempenho dos serviços de TI com foco no negócio institucional.

4. A equipe de auditoria examinou, ainda, se as estratégias e planos de TI são traçados em harmonia com o planejamento estratégico da instituição, a jurisprudência deste Tribunal e a IN SLTI 4/2010.

5. Quanto à gestão de pessoal de TI, procurou-se verificar se a instituição realiza avaliações quantitativas e qualitativas de seu quadro de profissionais alocados a essa área de forma a fundamentar futuros pleitos de ampliação e preenchimento de vagas, bem como se dispõe de plano periódico de capacitação.

6. A escolha dos aspectos examinados, bem como sua avaliação, baseou-se em normativos institucionais que tratam de fiscalização no âmbito deste Tribunal e decisões anteriores sobre a matéria, em especial o acórdão 1233/2012-TCU-Plenário.

7. Como critérios de auditoria, foram adotadas os seguintes modelos e normas de boas práticas: Cobit 5, da Information Systems Audit and Control Association (Isaca); NBR ISO/IEC 27002:2005 (NBR: 27002), 20000-2:2008 (NBR 20000-2) e 38500:2009 (NBR 38500); o Código de Melhores Práticas de Governança Corporativa do Instituto Brasileiro de Governança Corporativa (IBGC); e o Guia de Elaboração de Plano Diretor de Tecnologia da Informação (PDTI) do Sistema de Administração dos Recursos de Tecnologia da Informação (Sisp), assim definidos pela unidade técnica (grifos nossos):

"O Cobit 5 consiste em um modelo de boas práticas para governança e gestão de tecnologia da informação organizado em cinco grandes domínios: *Evaluate, Direct and Monitor* (EDM), *Align, Plan and Organize* (APO), *Build, Acquire and Implement* (BAI), *Deliver, Service and Support* (DSS) e *Monitor, Evaluate and Assess* (MEA), cujas siglas serão utilizadas no decorrer do relatório para fins de referência ao critério de auditoria.

A NBR 27002 consiste em um código de boas práticas para a gestão da segurança da informação amplamente adotado no mundo e tem como propósito prover uma base comum para o desenvolvimento de normas de segurança organizacional e das práticas efetivas de gestão da segurança, além de prover confiança nos relacionamentos entre as organizações, fornecendo aos seus usuários recomendações para a boa gestão da segurança da informação.

Por sua vez, a NBR 20000-2 estabelece um código de prática que descreve as melhores práticas para processos de gerenciamento de serviços dentro do escopo da ABNT NBR ISO/IEC 20000-1. Essa norma faz parte da série ABNT NBR ISO/IEC 20000, que habilita provedores de

serviços a entender como melhorar a qualidade dos serviços entregues aos seus clientes, tanto internos como externos.

Já a NBR ISO/IEC 38500 – norma de governança corporativa em tecnologia da informação – tem por objetivo fornecer uma estrutura de princípios para os dirigentes usarem na avaliação, no gerenciamento e no monitoramento do uso da tecnologia da informação em suas organizações. Essa norma oferece uma estrutura (contendo definições, princípios e um modelo) para a governança eficaz de TI que ajuda a alta administração das organizações a entender e cumprir suas obrigações legais, regulamentares e éticas com relação ao uso da TI em suas organizações.

O Código de Melhores Práticas de Governança Corporativa do IBGC propõe a adoção de princípios e boas práticas de governança corporativa, com vistas a reduzir eventuais fragilidades no sistema de governança das organizações, que se aplicam a qualquer tipo de organização, independente do porte, natureza jurídica ou tipo de controle. O código é adotado como referência para alguns controles e práticas que ajudam a orientar a organização como um todo e, por consequência, sua atuação na governança da TI.

Por fim, o Guia de Elaboração de PDTI do Sisp provê informações que ajudam as organizações a planejarem melhor as ações relacionadas a TI. Cabe ressaltar que, apesar do referido guia ser destinado às instituições que fazem parte do Sistema de Administração dos Recursos de Tecnologia da Informação (SISP), considerou-se que as informações ali contidas são boas práticas que poderiam ser aplicadas para as demais instituições fiscalizadas neste trabalho."

II

8. Realizados os exames e ouvidos os servidores e administradores vinculados aos achados, a equipe de auditoria firmou diversas conclusões, relacionadas, principalmente, a deficiências em termos de ações de melhoria de governança e de falhas nos mecanismos de direção e avaliação da gestão de TI na entidade auditada.
9. Acerca da **governança corporativa**, dois aspectos foram considerados responsáveis para a qualificação "inadequada" que a equipe atribuiu à implementação dos mecanismos de governança corporativa no âmbito da universidade: atuação deficiente da alta administração no monitoramento das políticas corporativas e falhas na divulgação do código de ética.
10. Com relação ao primeiro aspecto, constatou-se que não há, por parte da alta administração da universidade, o estabelecimento de políticas corporativas relativas à segurança da informação ou governança de TI. A única iniciativa relatada nesse sentido foi a elaboração de minuta de política de segurança da informação, a partir de iniciativa do Centro de Processamento de Dados (CPD) da UFAM, ainda não aprovada pela administração.
11. No que diz respeito especificamente à governança de TI, foram verificadas deficiências nas ações de melhoria de governança de TI, falhas na implementação do Comitê de TI e nos mecanismos para dirigir e avaliar a gestão e o uso corporativos de TI
12. A equipe de auditoria qualificou como achados, notadamente, a falta de definição dos papéis e responsabilidades nas decisões mais relevantes quanto à gestão e ao uso corporativo de TI, e a ausência de mecanismos de gestão de riscos relacionados aos objetivos de gestão e usos corporativos e de planos de auditorias internas para avaliar os riscos considerados críticos para o negócio.
13. Além disso, o comitê de TI da universidade não tem, em sua composição, representantes das principais áreas do negócio. Ademais, tal comitê foi designado formalmente, mas não realizou nenhuma reunião.
14. No que concerne ao item 'estratégias e planos', foram detectados que a entidade não possui planejamento estratégico de TI e PDTI formalizados, aprovados e publicados.

15. Identificaram-se também falhas na gestão de pessoal de TI. A partir de minuta de reforma administrativa do CPD da UFAM, a unidade técnica observou que o número de servidores alocados à área de TI é inferior ao apontado como necessário pela própria universidade.

16. No que diz respeito à **gestão de processos**, foram apontadas falhas relacionadas à gestão de acordos de nível de serviços, processos de gestão de segurança da informação, gestão de incidentes de segurança da informação, planejamento e gestão das contratações:

- gestão de acordos de nível de serviços: inexistência de catálogo formal de serviços de TI; inexistência de acordos de nível de serviço estabelecidos entre o setor de TI e as áreas internas; e inexistência de processo de gestão de nível de serviço de TI;
- processos de gestão de segurança da informação: inexistência de: processo de gestão da continuidade dos serviços de TI formalmente aprovado e publicado; processo de inventário dos ativos de informação; política de controle de acesso à informação (PCA); programas de conscientização e treinamento em segurança da informação; e processo de gestão de riscos de segurança da informação;
- gestão de incidentes de segurança da informação: ausência de um documento formalmente aprovado e publicado que contemple o processo de gestão dos incidentes de segurança da informação;
- planejamento e gestão das contratações de TI: inexistência de planejamento e gestão: inexistência de processo formal de contratação de bens e serviços de TI.

17. Dados os achados mencionados e os critérios de avaliação utilizados pela equipe de auditoria, as conclusões implícitas em seu relatório, quanto às questões de auditoria indicam implementação parcial dos mecanismos de gestão e governança.

III

18. Concomitantemente com o exame das questões de auditoria, avaliou-se a ocorrência de possíveis inconsistências entre as evidências de implementação dos controles de TI pesquisadas na auditoria e as respostas apresentadas pelos órgãos e entidades quando do levantamento do perfil de governança de TI de 2012 (GovTI2012). Foram detectadas inconsistências.

19. A equipe de auditoria considerou que as inconsistências encontradas decorrem de causas diversas, tais como: falhas de interpretação do questionário por parte do órgão/ente fiscalizado; falta de clareza de algumas perguntas do questionário; grau de rigor empregado pela instituição na autoavaliação.

20. As principais inconsistências relatadas estão resumidas no quadro a seguir:

Seção	Resposta apresentada no Perfil GovTI2012	Situação encontrada (referência aos parágrafos)
1.2 Em relação à estrutura de governança de TI, a Alta Administração da instituição:	A alta administração se responsabiliza pela avaliação e pelo estabelecimento das políticas de governança, gestão e uso corporativos de TI.	A alta administração não estabeleceu políticas corporativas, tais como política de segurança da informação e política de governança de TI (parágrafo 32)
	A alta administração designou representantes de todas as áreas relevantes para o negócio institucional para compor o Comitê de TI.	O comitê de TI não tem, em sua composição, representantes das principais áreas do negócio (parágrafo 40)
	A alta administração avalia e monitora o cumprimento das políticas de governança, gestão e uso corporativos de TI.	Não há instituição de tais políticas, logo não há monitoramento. (parágrafo 41)
1.3 Em relação ao desempenho institucional da gestão e	A alta administração estabeleceu objetivos de gestão e uso corporativo de TI	Não foram estabelecidos alguns mecanismos importantes para a alta administração dirigir e avaliar a gestão

Seção	Resposta apresentada no Perfil GovTI2012	Situação encontrada (referência aos parágrafos)
de uso corporativos de TI, a Alta Administração da instituição:	A alta administração estabeleceu metas de desempenho da gestão e do uso corporativos de TI, para 2012	e o uso corporativo de TI (parágrafo 42) Não foram estabelecidas metas de desempenho da gestão e do uso corporativos de TI, para 2012 (parágrafo 42)
2.2 Em relação ao processo de planejamento estratégico de TI, marque a opção que melhor descreve a sua instituição:	A instituição executa um processo periódico de planejamento estratégico de TI, embora este não esteja formalmente instituído. A elaboração do PDTI conta com a participação das áreas de negócio, e o PDTI é elaborado com o apoio do comitê de TI.	Não existe um processo formal de planejamento estratégico de TI (parágrafos 51 e 52) Não foi elaborado um PDTI (parágrafos 51 e 52)

21. Tal verificação possibilita subsidiar o aperfeiçoamento consistente do instrumento de levantamento e de avaliação de governança de TI.

IV

22. Considerados os parâmetros de avaliação utilizados e as conclusões reportadas pela equipe, as recomendações e determinações propostas são, na essência, adequadas, de forma que as acolho, com ajustes de forma e de tipo, e com exclusão daquelas cuja relação de pertinência não estava suficientemente demonstrada.

23. Por fim, é de capital importância realçar que a inobservância dos padrões de boas práticas mencionados anteriormente importa incorrer em sérios riscos, como bem apontou a equipe de auditoria:

- baixa efetividade de políticas importantes para o incremento da governança corporativa;
- limitações para o alcance da eficácia, eficiência e efetividade da TI para agregar valor ao negócio, com o fornecimento de serviços inadequados e dificuldades na priorização de esforços;
- desalinhamento das ações de TI com os objetivos das áreas de negócio, com aumento do riscos relacionados e da alocação inadequada de recursos financeiros e humanos;
- insuficiência de desempenho de TI, aumento dos riscos associados a TI e dúvidas quanto ao fato de a TI agregar valor ao negócio com riscos e custos aceitáveis;
- alta dependência tecnológica de fornecedores de solução de TI;
- desconhecimento, por parte dos clientes de TI, dos serviços oferecidos e aumento do risco de falhas na entrega dos serviços aos clientes internos, de acordo com as prioridades de negócio e dentro do orçamento estabelecido;
- desconhecimento pelos servidores dos procedimentos a serem adotados quando da ocorrência de incidentes de segurança da informação;
- contratação de soluções não ótimas para os negócios da instituição e aumento de custos nas contratações efetuadas.

24. Logo a alta administração da Fundação Universidade Federal do Amazonas deve ser alertada sobre os riscos atinentes à contratação de bens e serviços de TI a que está exposta ao não adotar adequadamente as boas práticas utilizadas como parâmetro de avaliação, bem como as recomendações exaradas nos acórdãos de referência.

Diante do exposto, manifesto-me pela aprovação do acórdão que ora submeto à apreciação deste Colegiado.



TCU, Sala das Sessões Ministro Luciano Brandão Alves de Souza, em 28 de maio de 2014.

WEDER DE OLIVEIRA
Relator

ACÓRDÃO Nº 1411/2014 – TCU – Plenário

1. Processo nº TC 021.792/2013-5.
2. Grupo I – Classe V – Assunto: Relatório de Auditoria.
3. Interessados/Responsáveis: não há.
4. Entidade: Fundação Universidade Federal do Amazonas.
5. Relator: Ministro-Substituto Weder de Oliveira.
6. Representante do Ministério Público: não atuou.
7. Unidade Técnica: Secretaria de Controle Externo no Amazonas (SECEX-AM).
8. Advogado constituído nos autos: não há.

9. Acórdão:

VISTOS, relatados e discutidos estes autos que tratam de auditoria realizada na Fundação Universidade Federal do Amazonas com vistas a avaliar a implementação dos controles de TI informados em resposta ao levantamento do perfil de governança de TI de 2012, bem como verificar a adoção de planos e estratégias para implementação e melhoria da governança de TI.

ACORDAM os Ministros do Tribunal de Contas da União, reunidos em Sessão do Plenário, ante as razões expostas pelo Relator, em:

9.1. recomendar à Fundação Universidade Federal do Amazonas que:

9.1.1. elabore e aprove formalmente processo de aprimoramento contínuo da governança de TI, a exemplo das boas práticas contidas no capítulo 3 do guia de referência da implementação do Cobit 5, que contemple, ao menos: definição de papéis e responsabilidades voltadas especificamente para a melhoria da governança de TI; realização de diagnósticos ou autoavaliações de governança e de gestão de TI; e definição e acompanhamento de metas de governança de TI e das ações necessárias para alcançá-las, com base em parâmetros de governança, necessidades de negócio e riscos relevantes;

9.1.2. aperfeiçoe a implementação do Comitê de Tecnologia da Informação no sentido de assegurar o seu funcionamento permanente, bem como a efetiva alocação de representantes de áreas relevantes para o negócio da entidade, em especial representantes das áreas de ensino e pesquisa, que constituem o negócio da entidade, conforme orientações contidas no Cobit 5, Prática de Gestão APO01.01 – Define the organisational structure (Definir a estrutura organizacional – tradução livre), atividades 7 e 8;

9.1.3. estabeleça, formalmente, em consonância com o disposto no item 9.1.1 do acórdão 2308/2010-TCU-Plenário e com base nas boas práticas contidas na seção 3.3 da ABNT NBR ISO/IEC 38500:2009:

9.1.3.1. objetivos de gestão e de uso corporativos de TI alinhados às estratégias de negócio;

9.1.3.2. indicadores de desempenho para os objetivos de gestão definidos;

9.1.3.3. metas de desempenho da gestão e do uso corporativos de TI para cada indicador definido;

9.1.3.4. mecanismos para que a alta administração acompanhe o desempenho da TI da instituição; e

9.1.3.5. mecanismos de gestão dos riscos relacionados aos objetivos de gestão e de uso corporativos de TI;

9.1.4. realize auditorias periódicas na área de tecnologia da informação da Entidade, em especial no que diz respeito à avaliação da governança de TI, dos sistemas de informação e de suas bases de dados, da segurança da informação e das aquisições de bens e serviços de TI, . em consonância com o disposto no item 9.10.2 do acórdão 1233/2012-TCU-Plenário;

9.1.5. estabeleça processo de planejamento estratégico de TI que contemple, pelo menos, as práticas descritas nos itens 9.1.2.1 a 9.1.2.6 do acórdão 1233/2012-TCU-Plenário;

9.1.6. institua formalmente o plano diretor de TI da Entidade, contemplando os seguintes elementos:

9.1.6.1. desdobramento das diretrizes estabelecidas em planos estratégicos, a exemplo do plano estratégico institucional e do plano estratégico de TI;

9.1.6.2. vinculação das ações de TI (atividades e projetos) a indicadores e metas de negócio;

9.1.6.3. vinculação das ações de TI a indicadores e metas de serviços ao cidadão;

9.1.6.4. vinculação entre as ações de TI priorizadas ao orçamento de TI;

9.1.6.5. quantitativo necessário (ideal) para a força de trabalho em TI;

9.1.7. adote providências no sentido de dotar o setor de TI com o quantitativo de pessoal adequado para suprir as necessidades de trabalho em TI, com fundamento nas orientações contidas no Cobit 5, Prática de Gestão APO07.01 – Maintain adequate and appropriate staffing, levando em consideração as necessidades de pessoal das demais áreas do órgão;

9.1.8. avalie a conveniência e a oportunidade de implementar processo de gestão de nível de serviço de TI, de forma a assegurar que níveis adequados de serviço sejam entregues para os clientes internos de TI, de acordo com as prioridades do negócio e dentro do orçamento estabelecido, conforme orientações contidas na seção 6.1.3 da ABNT NBR ISO/IEC 20.000-2:2008;

9.1.9. elabore, publique e mantenha atualizado catálogo de serviços de TI da Entidade, conforme orientações contidas no Cobit 5, Prática de Gestão APO09.02 – Catalogue IT-enabled services (Catalogar serviços de tecnologia da informação habilitados – tradução livre);

9.1.10. elabore e execute processo de gestão de continuidade dos serviços de TI, conforme orientações contidas no Cobit 5, DSS04.3 – Develop and implement a business continuity response (Desenvolver e implementar resposta à continuidade do negócio – tradução livre);

9.1.11. elabore, execute e teste periodicamente o plano de gestão de continuidade do negócio da Instituição, de forma a minimizar os impactos decorrentes de falhas, desastres ou indisponibilidades significativas sobre as atividades da Entidade, conforme orientações contidas na seção 14 da ABNT NBR ISO/IEC 27.002:2005, nas seções 8.6 e 8.7 da ABNT NBR 15999-1:2007 e no Cobit 5, DSS04.3 – Develop and implement a business continuity response (Desenvolver e implementar resposta à continuidade do negócio – tradução livre), em atenção às disposições contidas na NC–DSIC/GSI/PR 6/IN01, de 11 de novembro de 2009, e em consonância com o item 9.2 do acórdão 1603/2008-TCU-Plenário;

9.1.12. elabore e execute processo de gestão de ativos de informação da Entidade, conforme orientações contidas na seção 7.1 da ABNT NBR ISO/IEC 27.002:2005 e no Cobit 5, Processo BAI09 – Manage assets (Gerenciar ativos – tradução livre), em atenção ao disposto na NC–DSIC/GSI/PR 10/IN01, de 30 de janeiro de 2012;

9.1.13. elabore e aprove formalmente a política de controle de acesso a informações e recursos de TI, com base nos requisitos de negócio e de segurança da informação da Entidade, conforme orientações contidas na seção 11.1.1 da ABNT NBR ISO/IEC 27.002:2005, em atenção ao item 2.6 da NC–DSIC/GSI/PR 7/IN01, de 6 de maio de 2010, e em consonância com o item 9.2 do acórdão 1603/2008-TCU-Plenário;

9.1.14. implante programas de conscientização e treinamento em segurança da informação na Entidade, conforme orientações contidas na seção 8.2.2 da ABNT NBR ISO/IEC 27.002:2005, em atenção ao disposto na seção 3.2.5 da NC–DSIC/GSI/PR 2/IN01, 13 de outubro de 2008;

9.1.15. elabore e implemente processo de gestão de riscos de segurança da informação, conforme orientações contidas na seção 4 da ABNT NBR ISO/IEC 27.002:2005, em atenção ao disposto na NC–DSIC/GSI/PR 4/IN01, de 15 de fevereiro de 2013;

9.1.16. elabore e aprove formalmente a política de segurança da informação e comunicações da Entidade, que deve contemplar, em especial, os elementos estabelecidos no item 5.3 da NC – DSIC/GSI/PR 3/IN01, 30 de junho de 2009, e na seção 5.1.1 da ABNT NBR ISO/IEC 27.002:2005, em atenção ao art. 5º, inciso VII, da IN – GSI/PR 1/2008;

9.1.17. institua comitê gestor de segurança da informação e comunicações, conforme orientações contidas no item 6.1.2 da ABNT NBR ISO/IEC 27.002:2005;

9.1.18. designe formalmente responsável pela segurança da informação e comunicações da Entidade, à semelhança das orientações contidas no item 6.1.3 da ABNT NBR ISO/IEC 27.002:2005;

9.1.19. institua formalmente equipe de tratamento e resposta a incidentes em redes computacionais, à semelhança das orientações contidas na seção 13 da ABNT NBR ISO/IEC 27.002:2005.

9.1.20. implante formalmente processo de contratação de soluções de TI, adequando o processo definido na IN – SLTI/MP 4/2010 ao contexto da Entidade, conforme o item 9.2.9.9 do acórdão 1233/2012-TCU-Plenário;

9.1.21. em consonância com o item 9.2.9.9 do acórdão 1233/2012-TCU-Plenário, implante processo de gestão de contratos de soluções de TI, adequando o processo definido na IN – SLTI/MP 4/2010 ao contexto da Entidade.

9.2. determinar à Fundação Universidade Federal do Amazonas que inclua nos relatórios de gestão dos exercícios vindouros informações específicas que permitam o acompanhamento pelos órgãos de controle das ações afetas à governança de TI, conforme orientações contidas no item 7 e seus subitens do Anexo Único da Portaria-TCU 175/2013.

9.3. alertar a administração da Fundação Universidade Federal do Amazonas sobre os riscos atinentes à contratação de bens e serviços de TI, elencados no item 24 da proposta de deliberação, a que está exposta ao não adotar adequadamente as boas práticas utilizadas como parâmetro de avaliação, bem como as recomendações exaradas nos acórdãos de referência;

9.4. encerrar o presente processo e arquivar os autos.

10. Ata nº 19/2014 – Plenário.

11. Data da Sessão: 28/5/2014 – Ordinária.

12. Código eletrônico para localização na página do TCU na Internet: AC-1411-19/14-P.

13. Especificação do quorum:

13.1. Ministros presentes: Aroldo Cedraz (na Presidência), José Jorge, José Múcio Monteiro e Ana Arraes.

13.2. Ministros-Substitutos convocados: Augusto Sherman Cavalcanti, Marcos Bemquerer Costa e André Luís de Carvalho.

13.3. Ministro-Substituto presente: Weder de Oliveira (Relator).

(Assinado Eletronicamente)
AROLDO CEDRAZ
na Presidência

(Assinado Eletronicamente)
WEDER DE OLIVEIRA
Relator

Fui presente:

(Assinado Eletronicamente)
LUCAS ROCHA FURTADO
Procurador-Geral, em exercício